4 TIME

Q1. Cybercrime / cybercriminals and classification of cybercrimes

ANS

Cybercrime / Cybercriminals and Classification of Cybercrimes (10 Marks)

1. Introduction

- Cybercrime refers to any illegal activity carried out using computers, networks, or the internet.
- It involves unauthorized access, data theft, fraud, or any activity that violates the confidentiality, integrity or availability of information.
- With the increasing use of digital technologies, cybercrimes have become a major global threat.



2. Who are Cybercriminals?

- Cybercriminals are individuals or groups who use computers, networks or the internet to commit illegal activities for personal, financial, political or ideological gains.
- They exploit system vulnerabilities to steal data, cause damage or gain unauthorized access.

Types of Cybercriminals (based on motivation)

1. Hackers (Black Hat)	2. Organized Cybercriminals	3. Insiders	4. Cyber Terrorists	5. Script Kiddies
Gain unauthorized access to systems for malicious purposes.	Work in groups to carry out large-scale cybercrimes (e.g., cyber fraud, drug trafficking).	Employees or trusted persons who misuse access to organizational data.	Use cyberattacks to create fear, disrupt critical infrastructure or achieve political/ ideological goals.	New or unskilled attackers who use ready-made tools or scripts to perform attacks.

3. Classification of Cybercrimes

Cybercrimes can be classified in different ways. The most common classifications are:

A. Based on the Target/Victim

- **Crimes against Individuals** (e.g., online harassment, identity theft, cyber stalking)
- **Crimes against Organizations** (e.g., data breach, ransomware)
- **Crimes against Government** (e.g., cyber terrorism, hacking government websites)
- **Crimes against Society** (e.g., spreading fake news, hate propaganda, online fraud)

B. Based on the Nature of Crime

- **Unauthorized Access** (hacking, password cracking)
- **Data Theft** (stealing personal or financial information)
- **Malware Related Crimes** (virus, worm, Trojan horse, ransomware)
- **Fraud and Financial Crimes** (phishing, online banking fraud)
- **Content Related Crimes** (cyber defamation, obscenity, copyright violation)

C. Based on the Intent

- **Crimes for Financial Gain** (online fraud, credit card theft, phishing)
- **Crimes for Political/Ideological Gain** (cyber terrorism, hacking for protest)
- **Crimes for Personal Gain** (identity theft, cyber stalking)
- **Crimes for Revenge** (defamation, data leakage)

D. Based on the Technology Used

- **Network Based Crimes** (hacking, DDoS attacks)
- **Web Based Crimes** (website defacement, phishing)
- **Email Related Crimes** (spam, email spoofing)
- **Mobile Based Crimes** (mobile malware, SIM cloning)
- **Social Media Related Crimes** (fake profiles, cyber bullying)

Q2 Planning steps of cyberattacks by criminals

ANS

Planning Steps of Cyberattacks by Criminals (10 Marks)

1. Introduction

- Cybercriminals do not attack randomly. They plan the attack in a systematic manner to achieve their goals.
- The attack is carried out in multiple stages, from gathering information to maintaining access.
- Understanding these steps helps in preventing and detecting cyberattacks.

2. Goals of Cyberattacks



- Steal sensitive information (personal, financial, organizational)
- Gain unauthorized access to systems or networks
- Disrupt operations or cause damage
- Extort money (ransomware)
- Achieve political or ideological objectives (cyber terrorism)
- Gain financial profit
- Establish long-term control over the target system

3. Planning Steps of a Cyberattack

1 Reconnaissance (Information Gathering)

- Collect information about the target organization.
- Find employees, email IDs, IP addresses, system details, technologies used.
- Tools: WHOIS, Google Dorking, Social Media, LinkedIn, etc.

2 Scanning and Enumeration

- Scan the target network to find active systems, open ports, services and vulnerabilities.
- Use automated scanning tools.
- Tools: Nmap, Masscan, Nessus, OpenVAS, etc.

3 Gaining Initial Access

- Exploit vulnerabilities or use social engineering (phishing, fake emails, malicious attachments).
- Gain initial access to a system or network.
- Tools: Exploit kits, Phishing tools, Malware.

4 Maintaining Access (Persistence)

- Install backdoors, create hidden accounts, or use malware to maintain long-term access.
- So that they can return later even if the system is rebooted or patched.
- Tools: Trojans, RATs (Remote Access Trojans).

5 Privilege Escalation

- Gain higher privileges (e.g., from normal user to administrator).
- Exploit system vulnerabilities or misconfigurations.
- Tools: Privilege escalation exploits, Mimikatz, Pass-the-Hash techniques.

6 Achieving Objectives

- Carry out the main attack goal such as:
  - Steal data
  - Install ransomware
  - Disrupt services
  - Deface website
  - Use system for further attacks (e.g., botnet)

7 Covering Tracks

- Delete logs, clear history, remove malware.
- Use encryption or steganography to hide evidence.
- Redirect traffic to hide the source.
- Tools: Log cleaners, anti-forensic tools, VPN, Tor, etc.

4. Example: Phishing Attack Planning

1. **Recon** — Find employee emails from LinkedIn.
2. **Scan** — Check email server and security measures.
3. **Initial Access** — Send phishing email with malicious link.
4. **Maintain Access** — Install backdoor for future access.
5. **Escalate** — Gain admin privileges.
6. **Objective** — Steal sensitive data (e.g., customer database).
7. **Cover Tracks** — Delete logs and remove email traces.

5. Conclusion

- Cybercriminals follow a well-planned and systematic approach to carry out attacks.
- Each step is important for the success of the attack.
- Organizations should implement security measures at every stage to detect, prevent and mitigate such attacks.

Q3. Buffer overflow attack and mitigation

ANS

Buffer Overflow Attack and Mitigation (10 Marks)

1. Introduction

- Buffer overflow is a type of security vulnerability that occurs when a program writes more data into a buffer (memory location) than it can hold.
- It allows an attacker to overwrite adjacent memory locations, leading to unexpected behavior, program crash, or execution of malicious code.
- It is one of the most common and dangerous vulnerabilities, especially in low-level languages like C and C++.

2. What is a Buffer?

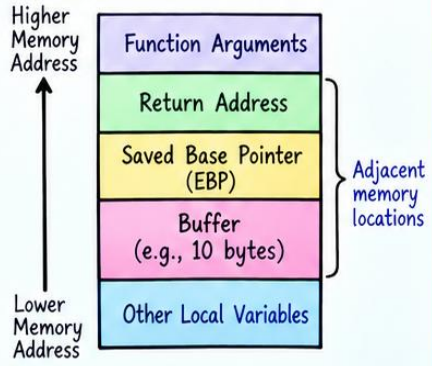
- A buffer is a fixed-size memory area used to store data temporarily (e.g., character array, string).
- Each buffer has a limited capacity.
- If more data is written than the allocated size, it overflows into adjacent memory locations.

3. How Buffer Overflow Occurs?

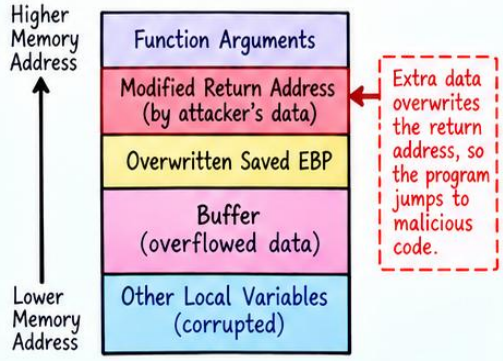
```
#include <stdio.h>
void vulnerable() {
  char buffer[10];  // can store 10 characters
  printf("Enter a string: ");
  gets(buffer);     // no boundary check (unsafe)
}
```

- If the user enters more than 10 characters, the data will overflow and overwrite adjacent memory (like return address).

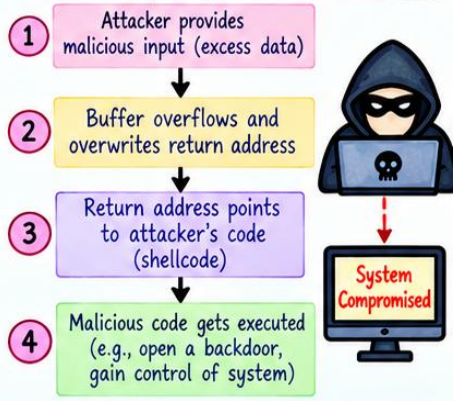
4. Normal Memory Layout



5. Memory After Buffer Overflow



6. Attack Execution Flow



7. Mitigation Techniques

1 Input Validation

- Check the size of input data.
- Use safe functions (e.g., fgets() instead of gets()).



2 Use Safe Libraries

- Use functions that perform bounds checking (e.g., strncpy(), snprintf()).



3 Stack Protection Mechanisms

- Stack canaries (additional random value to detect overflow).



4 Address Space Layout Randomization (ASLR)

- Randomizes memory addresses so attacker cannot predict the location of code.



5 Non-Executable Memory (NX bit)

- Marks memory regions (e.g., stack) as non-executable to prevent execution of malicious code.



6 Use of Modern Languages / Tools

- Use memory-safe languages (e.g., Java, Python).
- Use compiler security options (e.g., /GS, -fstack-protector).



Q4. Digital evidence: meaning, sources and types.

ANS

Digital Evidence: Meaning, Sources and Types (10 Marks)

1. Meaning of Digital Evidence

- Digital evidence refers to any information stored or transmitted in digital form that has probative value in a legal investigation or can be used as evidence in a court of law.
- It can be in the form of electronic data created, modified, accessed or stored on a computer, mobile device, network or any digital system.
- It helps in detecting, investigating and prosecuting cybercrimes.



Digital Evidence

2. Characteristics of Digital Evidence

- **Volatile** – can be easily altered or deleted.
- **Fragile** – may be lost if not handled properly.
- **Large volume** – huge amount of data.
- **Diverse** – found in many forms and devices.
- **Requires special tools** – for collection and analysis.
- **Admissible** – must follow legal procedures to be accepted in court.
- **Link to crime** – helps to establish what, when, how and who.

3. Sources of Digital Evidence

Computers/ Laptops



- Hard disk data
- System logs
- User files
- Deleted files

Mobile Devices



- Call logs
- Messages (SMS, chat apps)
- Contacts
- Photos / Videos
- Location data (GPS)

Storage Devices



- USB drives
- External hard disks
- Memory cards (SD cards, etc.)
- CD/DVDs

Network Devices



- Router / switch logs
- Firewall logs
- Network traffic (capture files)
- Emails

Cloud Services



- Cloud storage (Google Drive, OneDrive, Dropbox)
- Emails (Gmail, etc.)
- Online backups
- Cloud logs

Web / Online Sources



- Browser history
- Website logs
- Social media data
- Online transactions
- IP address records

Other Sources



- CCTV footage
- IoT devices (smart home devices)
- Printers, scanners
- GPS devices
- VoIP logs

4. Types of Digital Evidence

A. Based on Nature of Data

- **Active Evidence** – data currently in use (e.g., RAM, running processes).
- **Latent Evidence** – deleted/hidden data (e.g., deleted files, cache).
- **Static Evidence** – stored data (e.g., documents, images, logs).

B. Based on Data Structure

- **Structured Evidence** – well-organized data (e.g., databases, spreadsheets).
- **Unstructured Evidence** – no fixed format (e.g., emails, documents, images, videos).

C. Based on Source

- **Device-based Evidence** (computer, mobile, storage devices).
- **Network-based Evidence** (network logs, traffic data).
- **Cloud-based Evidence** (cloud storage, online accounts).
- **Application-based Evidence** (social media, email, web apps).

D. Based on Legal Context

- **Primary Evidence** – original data collected from the source.
- **Secondary Evidence** – duplicate/copy of data (for analysis).

E. Based on Form

- **Digital Documents** (text files, PDFs).
- **Images** (photos, screenshots).
- **Audio** (call recordings, voice messages).
- **Video** (CCTV, mobile videos).
- **Logs** (system, firewall, email).
- **Metadata** (file properties, location, timestamps).

Q5. HIPAA / IT security requirements

ANS

HIPAA / IT Security Requirements

(10 Marks)

1. Introduction to HIPAA

- HIPAA (Health Insurance Portability and Accountability Act) is a U.S. law enacted in 1996.
- It is designed to protect the privacy, security and confidentiality of individuals' health information (Protected Health Information - PHI).
- It applies to healthcare providers, health plans, healthcare clearinghouses and their business associates who handle PHI.

2. Objectives of HIPAA

- Protect the privacy and security of patient health information.
- Ensure confidentiality, integrity and availability of PHI.
- Provide patients with rights over their health information.
- Prevent unauthorized access, use or disclosure of PHI.
- Support secure electronic healthcare transactions.

3. Key Components of HIPAA

Privacy Rule (2000)

- Defines who can access and use PHI.
- Provides patients with rights over their health information.
- Sets limits on disclosure of PHI without consent.

Security Rule (2003)

- Sets standards to protect electronic PHI (ePHI).
- Requires administrative, technical and physical safeguards.

Breach Notification Rule (2009)

- Requires covered entities to notify affected individuals, HHS and in some cases, the media in case of a breach of unsecured PHI.

4. What is Protected Health Information (PHI)?

PHI is any information that can identify a patient and is related to their health, healthcare services or payment for healthcare.

Examples of PHI:

- Patient name, address, phone number
- Medical records and history
- Lab test results
- Diagnoses and treatment details
- Health insurance information
- Billing information



5. IT Security Requirements under HIPAA (Security Rule)

The HIPAA Security Rule requires three types of safeguards to protect electronic PHI (ePHI):

A. Administrative Safeguards

- Develop security policies and procedures.
- Conduct risk assessment and risk management.
- Provide workforce training and awareness.
- Implement access control policies.
- Assign security responsibility (officials).

B. Physical Safeguards

- Control physical access to facilities and devices where ePHI is stored.
- Use locks, access cards, CCTV surveillance.
- Ensure proper disposal of hardware and paper records.

C. Technical Safeguards

- Use unique user identification and authentication (passwords, MFA).
- Implement encryption for data at rest and in transit.
- Maintain audit logs and monitoring.
- Use firewalls, anti-malware and intrusion detection systems.

6. Other Important IT Security Measures

- Data encryption (at rest and in transit)
- Access control (least privilege)
- Regular security audits and monitoring
- Secure backup and disaster recovery
- Patch management and vulnerability management
- Secure configuration of systems and networks
- Incident response plan
- Business associate agreements (BAA)
- Compliance with HIPAA policies and procedures



7. Benefits of HIPAA Compliance

- Protects sensitive patient information.
- Builds trust between patients and healthcare providers.
- Reduces the risk of data breaches.
- Ensures legal compliance and avoids heavy penalties.
- Improves overall information security in healthcare organizations.

8. Conclusion

- HIPAA plays a critical role in protecting the privacy and security of healthcare information.
- IT security requirements under HIPAA ensure confidentiality, integrity and availability of ePHI through administrative, physical and technical safeguards.
- Compliance with HIPAA helps in secure and trustworthy healthcare systems.

3 TIME

Q6. E-contracts and their different types

ANS

E-contracts and their Different Types

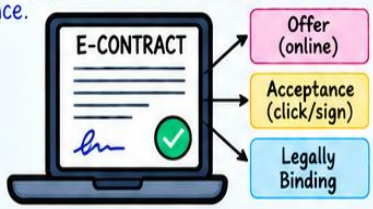
(10 Marks)

1. What is an E-contract ?

- An e-contract (electronic contract) is a legally binding agreement created, sent, received and stored in electronic form using digital means.
- It involves an offer, acceptance, consideration and intention to create legal relations, just like a traditional contract, but the process is carried out electronically (e.g., through email, website, app).
- E-contracts are recognized as valid under the Information Technology Act, 2000 in India and under international laws like UNCITRAL Model Law on Electronic Commerce.

2. Key Features of E-contracts

- Formed through electronic communication (email, website, app).
- Legally valid and enforceable.
- Uses digital signatures or electronic consent.
- Faster, more convenient and cost-effective than traditional contracts.
- Can be stored electronically.
- Supports global transactions (especially in e-commerce).
- Reduces paperwork and physical presence.



3. Legal Framework

- Information Technology Act, 2000 (India) provides legal recognition to electronic records and digital signatures.
- Section 10A: Validity of electronic contracts.
- Section 2(1)(t): Defines electronic contract.
- UNCITRAL Model Law on Electronic Commerce (international).
- E-contracts are enforceable if they satisfy the general principles of contract law (offer, acceptance, consideration, intention).

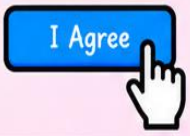


4. Types of E-contracts

1 Click-wrap Contracts

- User must click "I Agree" to the terms and conditions.
- Commonly used in software installation and websites.

Example: Software license agreement.



2 Browse-wrap Contracts

- Terms and conditions are available on the website (usually in a link).
- User's continued use of the website implies acceptance.

Example: Terms of use on e-commerce websites.



3 Shrink-wrap Contracts

- Terms are provided with the product packaging.
- User is deemed to accept the terms when the package is opened.

Example: Software purchased in a sealed package.



4 E-signature Contracts

- Contracts signed electronically using digital or electronic signatures.
- Legally valid under the IT Act, 2000.

Example: Online agreement signed with a digital signature.



5 E-commerce Contracts

- Contracts formed during online buying and selling of goods and services.
- Includes order, payment and delivery terms.

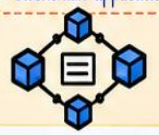
Example: Purchase of products on Amazon, Flipkart etc.



6 Smart Contracts

- Self-executing contracts with terms directly written in code (blockchain based).
- Automatically enforces the contract when conditions are met.

Example: Cryptocurrency transactions, blockchain applications.



5. Advantages and Disadvantages of E-contracts

Advantages

- ✓ Fast and convenient
- ✓ Cost-effective (no physical paperwork)
- ✓ Global reach
- ✓ Easy storage and retrieval
- ✓ Environment friendly (paperless)
- ✓ Supports e-commerce and digital business

Disadvantages

- ✗ Security risks (hacking, fraud)
- ✗ Identity verification issues
- ✗ Possibility of misunderstanding of terms
- ✗ Dependence on technology and internet
- ✗ Legal and jurisdictional challenges in cross-border contracts

6. Conclusion

- E-contracts have become an essential part of the digital economy, especially with the growth of e-commerce and online services.
- They are legally valid and enforceable when they meet the basic elements of a contract and comply with the IT Act, 2000.
- Different types of e-contracts are used in various scenarios, from simple click agreements to advanced smart contracts.
- Despite some challenges, e-contracts provide a fast, secure and efficient way to conduct business in the modern world.

Q7. SQL injection attack and prevention.

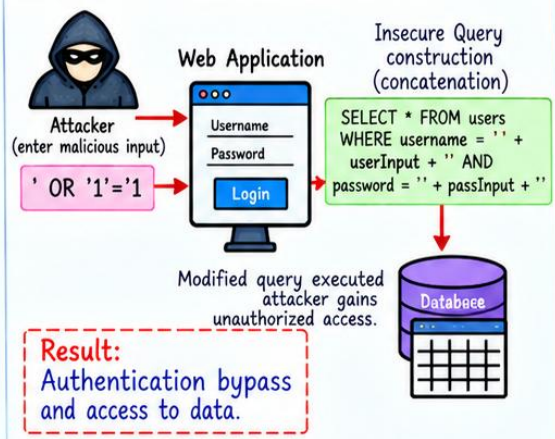
ANS

SQL Injection Attack and Prevention (10 Marks)

1. Introduction

- SQL Injection (SQLi) is a type of cyberattack in which an attacker inserts malicious SQL code into input fields of a web application to manipulate the backend database.
- It exploits poor input validation and insecure query construction.
- It can allow the attacker to bypass authentication, access, modify or delete data, and even gain control over the database server.

2. How SQL Injection Works ?



Result: Authentication bypass and access to data.

3. Example of SQL Injection

Normal Query (without attack)

Input: username = admin
password = 1234

Query:
```
SELECT * FROM users
WHERE username = 'admin'
AND password = '1234';
```

Malicious Query (with SQL Injection)

Input: username = ' OR '1'='1
password = --

Query:
```
SELECT * FROM users
WHERE username = ' OR '1'='1'
AND password = '--';
```

Result: Condition '1'='1' is always true, so the attacker can login without valid credentials.

4. Types of SQL Injection

1 Classic SQL Injection

- Directly injects malicious SQL code through input fields (e.g., login form, search box).

Example:
' OR '1'='1'

- Used to bypass authentication or extract data.

2 Blind SQL Injection

- Database does not show direct error messages, but attacker infers information from application behavior (True/False responses, time delay).

Example:
' AND 1=1 --
' AND 1=2 --

- Used to extract data bit by bit.

3 Error-based SQL Injection

- Uses database error messages to get information about the database structure.

Example:
' UNION SELECT NULL, version(), NULL --

- Error messages reveal table names, column names, etc.

4 Union-based SQL Injection

- Uses the UNION operator to combine results from multiple SELECT statements and extract data from other tables.

Example:
' UNION SELECT username, password FROM users --

- Used to read sensitive data from other tables.

5. Impact / Consequences

- Unauthorized access to sensitive data (personal, financial, etc.)
- Modification or deletion of data in the database
- Bypass authentication and gain admin privileges
- Complete control over database server
- Data breach, financial loss, reputation damage and legal consequences

6. Prevention / Mitigation Techniques

1 Use Parameterized Queries (Prepared Statements)

- Separates SQL code from user input.
- Prevents malicious input from being executed.

2 Input Validation and Sanitization

- Validate and sanitize user input.
- Use whietlist (allow only expected values).

3 Use Stored Procedures

- Use stored procedures with parameters instead of dynamic SQL queries.

4 Least Privilege Access

- Give minimum necessary permissions to database users.
- Do not use admin accounts in applications.

5 Use Web Application Firewall (WAF)

- Detects and blocks SQL injection attempts.
- Monitors and filters malicious traffic.

6 Error Handling and Logging

- Do not display detailed database error messages to users.
- Use proper error handling and maintain logs for suspicious activities.

Q8. E-commerce and types

ANS

E-commerce and Types

(10 Marks)

1. Introduction to E-commerce

- E-commerce (Electronic Commerce) refers to the buying and selling of goods and services over the internet using electronic means.
- It involves online transactions, electronic payments, digital marketing and electronic exchange of data.
- E-commerce allows businesses and customers to conduct commercial activities without physical presence.
- It has made shopping, banking, travel, education and many other services more convenient, faster and global.

Examples:
Amazon, Flipkart, Myntra, eBay, online banking, online ticket booking, food delivery apps, etc.

2. How E-commerce Works ?



3. Features of E-commerce

- Global Reach – can operate worldwide.
- 24×7 Availability – customers can shop anytime, anywhere.
- Convenience – no physical visit required.
- Wide Product Range – variety of products and services.
- Cost Effective – reduces operational costs.
- Electronic Transactions – secure online payments.
- Personalization – product recommendations.
- Easy Comparison – compare prices and features.
- Digital Marketing – reach more customers.
- Paperless Process – less paperwork and faster transactions.

4. Types of E-commerce

1. B2C (Business to Consumer)

- Business sells directly to individual consumers.
- Most common type of e-commerce.
- Examples: Amazon, Flipkart, Myntra.



2. B2B (Business to Business)

- Transactions between two businesses.
- Used for wholesale, supply chain and raw materials.
- Examples: Alibaba, IndiaMART.



3. C2C (Consumer to Consumer)

- Consumers sell products or services to other consumers.
- Platform provides a marketplace.
- Examples: OLX, eBay, Quikr.



4. C2B (Consumer to Business)

- Individuals offer products or services to businesses.
- Businesses purchase those products/services.
- Examples: Freelancing platforms (Upwork, Fiverr), stock photos, content writing.



5. B2G (Business to Government)

- Businesses provide goods or services to government organizations.
- Includes e-procurement and online tenders.
- Examples: Government e-Marketplace (GeM), online tendering systems.



6. G2C (Government to Citizen)

- Government provides services to citizens online.
- Examples: Online tax filing, passport application, Aadhaar services, government certificates.



5. Advantages and Disadvantages

Advantages	Disadvantages
✓ Convenient and time-saving.	✗ Security and privacy risks.
✓ Global reach and wider customer base.	✗ Dependence on internet and technology.
✓ Lower operational costs.	✗ No physical inspection of products.
✓ 24×7 availability.	✗ Risk of online fraud and fake products.
✓ Variety of products and services.	✗ Delivery delays.
✓ Easy price comparison.	✗ Lack of personal interaction.
✓ Growth of digital economy.	✗ Legal and regulatory challenges.

6. Conclusion

- E-commerce has transformed the way businesses and consumers interact by providing a fast, convenient and efficient platform for buying and selling goods and services.
- Different types of e-commerce (B2C, B2B, C2C, C2B, B2G, G2C) serve different needs in the digital economy.
- Despite some challenges, e-commerce continues to grow and plays a vital role in the global economy, offering new opportunities for businesses and consumers.

Q9. DoS / DDoS attacks.

ANS

DoS / DDoS Attacks

(10 Marks)

1. Introduction

- Denial of Service (DoS) and Distributed Denial of Service (DDoS) are cyberattacks that aim to **make a system, network or online service unavailable** to legitimate users.
- Attackers flood the target with huge amounts of traffic or malicious requests, exhausting its resources (bandwidth, CPU, memory, etc.).
- The service becomes slow or completely unavailable.

2. DoS Attack

- DoS (Denial of Service) attack is launched from a **single source** (attacker's system).
- Attacker sends a large number of requests to the target server.
- It consumes the server's resources (bandwidth, CPU, memory, connections).
- Legitimate users are unable to access the service.

Example: Sending a large number of HTTP requests to a web server so that it cannot respond to genuine users.

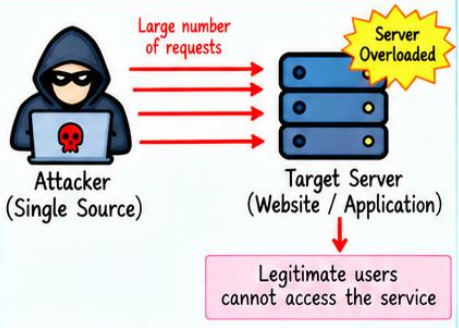
3. DDoS Attack

- DDoS (Distributed Denial of Service) attack is launched from **multiple compromised systems** called a **botnet** (e.g., infected computers, IoT devices).
- Many systems simultaneously send massive traffic to the target.
- It is harder to detect and prevent because the attack comes from many different sources and locations.
- It can generate a huge amount of traffic, making the targeted service completely unavailable.

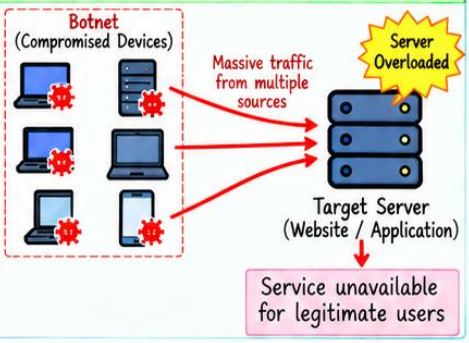
Example: A botnet of thousands of infected devices sending traffic to a website, causing it to crash.

4. Working of DoS and DDoS Attack

Working of DoS Attack (Single Source)



Working of DDoS Attack (Multiple Sources)



5. DoS vs DDoS (Key Differences)

Feature	DoS	DDoS
Source	Single system	Multiple systems (botnet)
Attack traffic	Less (from one machine)	Very high (from many machines)
Complexity	Easier to launch	More complex to launch
Detection	Relatively easier	Difficult to detect
Impact	Limited	Very large, wide-scale
Example	Flooding a server with HTTP requests	Botnet of IoT devices attacking a website

6. Types of DoS / DDoS Attacks

1 Volumetric Attacks	Floods the network with huge traffic (e.g., UDP flood, ICMP flood).
2 Protocol Attacks	Exploits weaknesses in network protocols (e.g., SYN flood, Ping of Death).
3 Application Layer Attacks	Targets specific application services (e.g., HTTP flood, Slowloris).
4 Amplification Attacks	Uses third-party servers to amplify traffic (e.g., DNS amplification, NTP amplification).

7. Prevention and Mitigation Techniques

- Use firewalls and Intrusion Detection/Prevention Systems (IDS/IPS).
- Implement rate limiting and traffic filtering.
- Use Content Delivery Networks (CDNs) to absorb large traffic.
- Block suspicious IP addresses and use blacklists.
- Use load balancing and scalable cloud infrastructure.
- Keep systems and software updated.
- Monitor network traffic and set up alert systems.
- Use anti-DDoS services provided by ISPs or cloud providers (e.g., AWS Shield, Cloudflare).

8. Conclusion

- DoS and DDoS attacks are serious threats that can make online services unavailable and cause financial and reputational losses.
- DDoS attacks are more powerful and difficult to prevent due to their distributed nature.
- A combination of security measures, monitoring and scalable infrastructure is required to defend against these attacks.

Q10. Vishing attack: working and prevention

ANS

Vishing Attack : Working and Prevention

(10 Marks)

1. Introduction

- Vishing (Voice Phishing) is a type of social engineering attack in which attackers use phone calls or voice communication to trick individuals into revealing sensitive information.
- It is similar to phishing, but instead of emails or messages, it is done through voice calls.
- The attacker often pretends to be a legitimate person or organization (e.g., bank, government, IT support) to gain the victim's trust.

2. Common Targets and Goals

Targets:

- Individual users (bank customers, employees, senior citizens).
- Employees of organizations.
- Customers of financial, healthcare and government services.



Goals:

- To steal personal and financial information (account numbers, OTPs, credit card details).
- To gain unauthorized access to accounts.
- To install malware or obtain remote access.
- To perform financial fraud or identity theft.

3. Working of Vishing Attack

1. **Attacker Preparation** — Collects information about the target (name, phone number, bank details, etc.) from social media, data breaches or other sources.



2. **Initial Contact** — Calls the victim posing as a trusted organization (e.g., bank, telecom company, government agency).



3. **Building Trust** — Uses convincing conversation, urgent messages or fake verification processes to gain the victim's trust.



4. **Extracting Information** — Tricks the victim into revealing sensitive details such as OTP, PIN, passwords or account information.



5. **Misuse of Information** — Uses the collected information to perform fraud, unauthorized transactions or gain access to systems.



4. Example Scenario of Vishing Attack



Result: Attacker uses the OTP to access the victim's bank account and performs unauthorized transactions.

5. Techniques Used in Vishing Attacks

Technique	Description
Caller ID Spoofing	Shows fake caller ID (e.g., bank's official number) to appear legitimate.
Social Engineering	Uses fear, urgency or rewards to manipulate victims (e.g., account suspension, lucky draw).
Pretexting	Pretends to be a bank official, government employee or technical support staff.
Voice Cloning (Advanced)	Uses AI to mimic a trusted person's voice.
Interactive Voice Response (IVR) Fraud	Tricks users into entering sensitive details through fake IVR systems.

6. Prevention / Mitigation Measures

- Never share OTP, PIN, passwords or confidential information over phone calls.
- Verify the caller's identity by contacting the official customer care number.
- Do not trust urgent or threatening messages.
- Be aware of social engineering tactics.
- Use call blocking and spam detection apps.
- Educate and create awareness among users (especially senior citizens).
- Organizations should implement employee training and strict verification processes.
- Report suspicious calls to the bank or authorized cybercrime portal.

Remember: Legitimate organizations never ask for OTP, PIN or passwords on a phone call.

7. Conclusion

- Vishing is a serious cyber threat that exploits human psychology through voice communication.
- It can lead to financial loss, identity theft and unauthorized access to accounts.
- By staying alert, verifying callers and following safety practices, individuals and organizations can effectively prevent vishing attacks.

Q11. Safeguarding laptops and wireless devices

ANS

Safeguarding Laptops and Wireless Devices

(10 Marks)

1. Introduction

- Laptops and wireless devices (smartphones, tablets, smartwatches, etc.) are widely used for personal, educational and business purposes.
- They store sensitive data and connect to networks, making them attractive targets for attackers.
- Safeguarding these devices is essential to ensure confidentiality, integrity and availability of data.



2. Security Threats to Laptops and Wireless Devices

1. **Malware** (viruses, worms, ransomware)
2. Unauthorized access (theft, hacking)
3. Data leakage (loss or theft of sensitive information)
4. Insecure wireless networks (public Wi-Fi, fake hotspots)
5. Phishing and social engineering (fake emails, messages, calls)
6. Physical theft or loss
7. Eavesdropping and data interception (especially in wireless communication)
8. Unpatched software and system vulnerabilities

3. Best Practices to Safeguard Laptops

Use Strong Authentication
- Use strong passwords or passphrases.
- Enable multi-factor authentication (MFA).

Encrypt Data
- Use full disk encryption (e.g., BitLocker, FileVault).
- Encrypt sensitive files and use secure cloud storage.

Keep OS and Software Updated
- Regularly install security patches and updates.
- Keep antivirus/anti-malware software updated.

Use Firewall and Security Software
- Enable built-in firewall.
- Use trusted antivirus/anti-malware tools.

Secure Data and Backups
- Take regular backups (external drive or cloud).
- Store sensitive data in encrypted form.

Prevent Physical Theft or Loss
- Use laptop locks and keep devices in safe places.
- Enable "Find My Device" and remote wipe.

4. Best Practices to Safeguard Wireless Devices

Use Secure Wi-Fi Networks	• Avoid public Wi-Fi for sensitive transactions. • Use WPA2/WPA3 encryption at home and work.
Use VPN	• Use a trusted VPN when accessing public networks. • Encrypts internet traffic and hides your identity.
Enable Device Security Features	• Use screen lock (PIN, pattern, password, biometric). • Enable device encryption.
Keep Firmware and Apps Updated	• Regularly update OS, firmware and apps. • Patch security vulnerabilities.
Turn Off Wireless Features When Not in Use	• Disable Wi-Fi, Bluetooth, NFC and location services when not required.
Install Apps from Trusted Sources	• Use official app stores (Google Play Store, Apple App Store). • Avoid third-party or unknown applications.
Review Permissions	• Give only necessary permissions to apps. • Regularly review and remove unused apps.
Use Secure Cloud Services	• Use trusted cloud providers with encryption. • Enable MFA for cloud accounts.

5. Additional Safety Measures

- Be cautious of phishing emails, messages and suspicious links.
- Use strong, unique passwords for all accounts.
- Avoid sharing sensitive information on insecure channels.
- Use endpoint security solutions.
- Regularly monitor device activity and login attempts.
- Use secure file sharing methods.
- Disable auto-connect to open Wi-Fi networks.
- Use MAC address filtering in wireless routers.
- Separate personal and work data/profiles.
- Educate users about safe online behaviour.

6. Safe Wireless Network Setup

Key Settings for Home/Office Wi-Fi

1. Use WPA2/WPA3 encryption.
2. Change default router username and password.
3. Disable WPS (Wi-Fi Protected Setup).
4. Use a strong network password.
5. Keep router firmware updated.
6. Enable network monitoring and logs.
7. Use a separate guest network for visitors.
8. Disable remote management (if not required).



7. Conclusion

- Laptops and wireless devices are essential in today's digital world but are vulnerable to many security threats.
- By following best practices such as strong authentication, encryption, regular updates, secure network settings and user awareness, we can significantly reduce the risks of data theft, unauthorized access and other cyberattacks.
- A combination of technical measures and safe user behaviour is necessary to ensure the security of laptops and wireless devices.

Q12. Security risks / challenges for organizations and mobile devices.

ANS



Q13. Objectives / features of IT Act 2000.

ANS

Objectives / Features of IT Act 2000

(10 Marks)

1. Introduction

- The Information Technology Act, 2000 is a landmark legislation in India.
- It was enacted to provide legal recognition to electronic records, electronic signatures and electronic transactions.
- It aims to promote the growth of the IT industry, e-commerce and digital governance.
- It also defines cyber offences and prescribes penalties for various computer-related crimes.



2. Objectives of IT Act 2000

1. To provide legal recognition to electronic records and electronic signatures.
2. To facilitate electronic filing of documents with Government agencies.
3. To promote e-commerce and electronic governance.
4. To create a legal framework for cyber security and to prevent computer-related crimes.
5. To define offences, prescribe penalties and provide a mechanism for investigation and adjudication.
6. To protect sensitive personal data and ensure privacy.
7. To encourage the use of IT for economic and social development.

3. Key Features of IT Act 2000

Legal recognition of electronic records	Electronic records are considered at par with paper records (Section 4).
Legal recognition of digital signatures	Digital signature is recognized as valid (Section 3) using Public Key Infrastructure (PKI).
Facilitation of e-commerce	Provides legal framework for electronic contracts and e-commerce (Section 10A).
Definition of cyber offences	Defines various offences like hacking, data theft, tampering with computer source documents (Sections 43, 66, 66C, 66D etc.).
Penalties and adjudication	Prescribes civil and criminal penalties and provides for adjudicating officers (Sections 46-58).
Regulation of Certifying Authorities	Provides for licensing and regulation of Certifying Authorities (Sections 17-34).
Amendments and upgrades	Later amended in 2008 to include more offences, data protection and cyber terrorism.

4. Important Provisions (Sections)

Section	Description
Section 3	Recognition of digital signature.
Section 4	Legal recognition of electronic records.
Section 5	Legal recognition of electronic signatures.
Section 10A	Validity of electronic contracts.
Section 17-34	Regulation of Certifying Authorities.
Section 43	Penalty for damage to computer systems, data, etc. (civil liability).
Section 66	Computer-related offences (hacking, dishonestly accessing data, etc.).
Section 66C	Identity theft.
Section 66D	Cheating by personation using computer resources (e.g., online fraud).
Section 66F	Cyber terrorism.
Section 67	Publishing or transmitting obscene material in electronic form.

5. Advantages / Significance

- Gives legal validity to electronic transactions.
- Encourages e-commerce and digital governance.
- Helps in controlling and preventing cyber crimes.
- Builds trust in online transactions.
- Supports the growth of the IT industry.
- Provides legal protection to data and privacy.
- Facilitates secure and reliable digital communication.



6. Limitations / Challenges

- Technology evolves faster than the law.
- Some provisions were not sufficient to deal with new types of cyber crimes (hence amendment in 2008).
- Implementation and enforcement can be difficult.
- Lack of awareness among users.
- Cross-border cyber crimes are hard to control.
- Need for continuous updates to address emerging threats.

7. Conclusion

- The IT Act, 2000 is a crucial step towards building a secure legal framework for the digital economy in India.
- It provides recognition to electronic records and signatures, promotes e-commerce, and defines cyber offences with penalties.
- It plays an important role in ensuring trust, security and growth in the use of information technology.

Q14. Intellectual property aspects in cyber law.

ANS

Intellectual Property Aspects in Cyber Law

(10 Marks)

1. Introduction

- Intellectual Property (IP) refers to creations of the mind such as inventions, literary and artistic works, designs, symbols, names, and software.
- In the digital world (cyberspace), these creations are easily copied, shared and distributed, which increases the risk of infringement.
- Cyber law provides legal protection to IP rights in electronic form and deals with new challenges like online piracy, software theft, domain name disputes, etc.

2. Types of Intellectual Property and their Protection in Cyber Law

Type	Meaning	Examples (in Digital World)	Governing Law (in India)
Copyright ©	Protection to original literary, artistic and musical works.	Software, websites, e-books, digital photos, videos, mobile apps, databases.	Copyright Act, 1957 (amended 2012)
Trademark TM	Protection to distinctive marks, logos, brand names.	Domain names, website logos, product names used online.	Trade Marks Act, 1999
Patent	Protection to new inventions and processes.	New software technology, hardware design, business methods (if eligible).	Patents Act, 1970 (amended 2005)
Design	Protection to aesthetic design and appearance.	GUI designs, icons, product interface designs.	Designs Act, 2000
Geographical Indications GI	Protection to goods with specific geographical origin.	Online sale of GI tagged products (e.g., Darjeeling Tea).	Geographical Indications of Goods Act, 1999

3. Major IP Issues in Cyberspace

1. **Online Piracy** – Unauthorized copying and distribution of digital content (movies, music, e-books, software).
2. **Software Theft** – Illegal copying or use of licensed software.
3. **Domain Name Disputes** – Use of similar domain names leading to brand confusion (e.g., cybersquatting).
4. **Counterfeiting** – Fake websites and products with similar trademarks.
5. **Unauthorized Sharing** – Sharing of copyrighted content on file sharing networks, cloud storage or social media.
6. **Data and Database Protection** – Unauthorized extraction and use of online databases.
7. **Digital Rights Management (DRM) issues** – Bypassing security measures to access protected content.

4. Legal Protection under Cyber Law

- The Information Technology Act, 2000 supports the protection of IP rights in electronic form.
- Recognizes electronic records and digital signatures as legally valid (useful in IP transactions).
- Provides penalties for unauthorized access, copying, modification or distribution of digital content.
- Sections 43, 66 and 66C–66F deal with computer related offences including infringement and data theft.
- Works along with other IP laws like Copyright Act, Trade Marks Act, Patents Act and Designs Act.



5. Challenges in Enforcing IP Rights in Cyberspace

- Ease of copying and fast distribution of digital content.
- Determining jurisdiction (offence may occur in different countries).
- Anonymous users and difficulty in identifying the actual infringer.
- Cross-border nature of the internet.
- Lack of awareness among users.
- Rapid technological changes (new methods of infringement).
- Cost and time involved in legal proceedings.
- Balancing IP rights with freedom of information and fair use.



6. Measures to Protect IP in Cyberspace

1. Use of digital watermarking and encryption.
2. Implement Digital Rights Management (DRM).
3. Register copyrights, trademarks, patents and domain names.
4. Monitor and take legal action against infringing websites and users.
5. Use technological measures (access controls, licensing, anti-piracy tools).
6. Create awareness about respecting IP rights.
7. International cooperation and treaties (e.g., WIPO, TRIPS) to handle cross-border infringement.

7. Conclusion

- Intellectual property is a valuable asset in the digital economy and needs strong protection in cyberspace.
- Cyber law, along with traditional IP laws, provides legal framework to protect IP rights.
- However, new challenges such as online piracy, domain name disputes and cross-border infringement require continuous technological, legal and awareness measures.
- Proper enforcement and global cooperation are essential to safeguard intellectual property in the digital world.

Q15. Cybercrime differs from terrestrial crimes

ANS

Cybercrime differs from Terrestrial Crimes

(10 Marks)

1. Introduction

- Cybercrime refers to illegal activities performed using computers, networks, the internet or digital devices.
- Terrestrial crimes are traditional crimes committed in the physical world without the use of digital technology.
- Although both types of crimes involve violation of law, cybercrimes have unique characteristics and challenges due to the digital and borderless nature of cyberspace.



Cybercrime (digital world)



Terrestrial crime (physical world)

2. Comparison between Cybercrime and Terrestrial Crime

Aspect	Cybercrime	Terrestrial Crime
Medium	Uses computers, networks and internet.	Occurs in physical world using physical means.
Nature	Virtual / digital, no physical presence required.	Physical, requires direct human interaction.
Location	Can be committed from anywhere in the world (borderless).	Limited to a specific geographical area.
Evidence	Digital evidence (logs, IP addresses, metadata) – easy to alter or delete.	Physical evidence (weapons, fingerprints, (CCTV, etc.) – hard to destroy.
Anonymity	High anonymity (use of proxies, VPN, dark web).	Difficult to remain anonymous.
Speed	Can be executed very quickly and on a large scale.	Relatively slower and limited in scale.
Victims	Can target many victims simultaneously worldwide.	Usually limited number of victims.
Jurisdiction	Involves multiple countries and different legal systems.	Generally falls under local / national jurisdiction.

3. Key Differences (Detailed)

1. **Use of Technology**
   - Cybercrime depends on computers, networks and digital tools.
   - Terrestrial crime does not require technology.
2. **Geographical Scope**
   - Cybercrime is borderless and can be committed from any country.
   - Terrestrial crime is location specific.
3. **Nature of Attack**
   - Cybercrime can be carried out remotely without physical contact.
   - Terrestrial crime usually requires physical presence.
4. **Type of Evidence**
   - Cybercrime leaves digital evidence which is volatile and can be easily modified.
   - Terrestrial crime leaves physical evidence which is more stable.
5. **Anonymity and Identity**
   - Cybercriminals can hide their identity using technical means.
   - In terrestrial crimes, it is difficult to remain completely anonymous.
6. **Scale and Impact**
   - Cybercrime can affect thousands or millions of users at the same time.
   - Terrestrial crime usually affects a limited number of people.

4. Examples

Cybercrime Examples

- Hacking and unauthorized access
- Phishing and online fraud
- Identity theft
- Malware and ransomware attacks
- Online banking fraud
- Cyberstalking and cyberbullying



Terrestrial Crime Examples

- Theft and burglary
- Robbery
- Assault and physical violence
- Fraud in person
- Vandalism
- Drug trafficking



5. Reasons for Differences

- Digital and borderless nature of the internet.
- Ease of hiding identity using technology.
- High dependence on digital data and networks.
- Lack of standardized international laws.
- Rapid technological advancements.
- Large number of potential victims.
- Difficulty in collecting and preserving digital evidence.



6. Implications

- Requires specialized laws and investigation techniques.
- Need for international cooperation.
- Digital forensics is essential.
- Organizations and individuals must adopt strong cybersecurity measures.
- More challenges in prosecution due to cross-border jurisdiction and anonymity.
- Greater financial and reputational losses due to large-scale attacks.



7. Conclusion

- Cybercrime is fundamentally different from terrestrial crime due to its digital nature, borderless reach, high anonymity, unique evidence and large-scale impact.
- These differences require new legal frameworks, specialized investigation techniques and international cooperation.
- Understanding these differences is important to effectively prevent, detect and prosecute cybercrimes.

Q16. Cybercrime vs cyber fraud

ANS

Cybercrime vs Cyber Fraud

(10 Marks)

1. Introduction

- With the increasing use of computers, internet and digital technologies, crimes are now also committed in the cyber world.
- Cybercrime and cyber fraud are two important terms often used together, but they are not the same.
- Every cyber fraud is a cybercrime, but every cybercrime is not a cyber fraud.



Cybercrime
(Any illegal activity in digital world)



Cyber Fraud
(Deceit to gain financial or other personal benefit)

2. Meaning and Definition

Cybercrime

- Cybercrime refers to any illegal activity carried out using computers, networks, the internet or digital devices.
- It includes a wide range of offences such as hacking, malware attacks, data theft, identity theft, cyber stalking, online harassment, etc.
- It may or may not involve financial gain.

Cyber Fraud

- Cyber fraud is a type of cybercrime in which the criminal uses digital means to deceive a person or organization to obtain financial or other material benefits.
- It involves misrepresentation, cheating or tricking the victim through online platforms.
- The main motive is to gain money, property or valuable information by fraud.

3. Key Differences

Aspect	Cybercrime	Cyber Fraud
Meaning	Any illegal activity using computers or internet.	Deceptive activity to gain financial or material benefit (Subset of cybercrime).
Scope	Wide (includes many types of offences).	Narrow (only fraud related offences).
Motive	May or may not involve financial gain.	Always involves deceiving the victim for financial or material gain.
Examples	Hacking, malware, denial of service, cyber stalking, data theft, etc.	Online banking fraud, credit card fraud, phishing, e-commerce fraud, UPI fraud, etc.
Victim	Individuals, organizations, government, society.	Individuals or organizations (mainly for financial loss).
Impact	Data loss, system damage, privacy breach, reputational loss.	Financial loss, theft of money or valuable information.
Legal Provisions (India)	IT Act, 2000 (Sections 43, 66, 66B, 66C, 66D, etc.)	IT Act, 2000 (especially Section 66D), IPC sections (cheating, forgery), Banking laws.

4. Examples of Cybercrime (without financial fraud)

1. Hacking and unauthorized access
2. Malware / ransomware attacks
3. Denial of Service (DoS) attacks
4. Cyber stalking and online harassment
5. Website defacement
6. Data theft and privacy violation



Malware Attack



Hacking



Data Theft

5. Examples of Cyber Fraud (with financial motive)

1. Phishing (fake emails to steal bank details)
2. Online banking fraud (unauthorized transactions)
3. Credit / debit card fraud
4. UPI and mobile wallet fraud
5. E-commerce fraud (fake websites, non-delivery of goods)
6. Investment fraud (fake schemes, crypto fraud)



Phishing



Credit Card Fraud



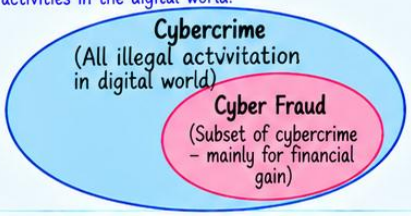
UPI Fraud



E-commerce Fraud

6. Relationship between Cybercrime and Cyber Fraud

- Cyber fraud is a subset of cybercrime.
- All cyber frauds are cybercrimes, but all cybercrimes are not cyber frauds.
- Cyber fraud specifically involves deception for financial or material gain.
- Cybercrime covers a broader range of illegal activities in the digital world.



7. Importance of Distinguishing

- Helps in proper classification and investification of cases.
- Different legal provisions and penalties may apply.
- Helps organizations to implement appropriate security measures.
- Useful for awareness and preventive strategies.



8. Prevention Measures

- Use strong passwords and enable multi-factor authentication.
- Be careful with suspicious emails, links and websites.
- Use trusted and updated security software.
- Verify websites and check URL before making online payments.
- Keep personal and financial information secure.
- Report suspicious activities to authorities.

9. Conclusion

- Cybercrime is a broad term that includes all illegal activities using computers and internet.
- Cyber fraud is a specific type of cybercrime that involves deception for financial gain.
- Understanding the difference helps in better prevention, legal action and cybersecurity awareness.

Q17. Electronic banking in India and related laws

ANS

Electronic Banking in India and Related Laws

(10 Marks)

1. Introduction

- Electronic banking (e-banking) refers to the use of electronic and digital channels to perform banking transactions without visiting a physical bank branch.
- In India, e-banking has grown rapidly due to internet penetration, mobile usage and government initiatives like Digital India and UPI.
- It provides customers with faster, convenient, secure and cost-effective banking services.



2. Modes / Types of Electronic Banking in India

Internet Banking	Mobile Banking (m-Banking)	ATM Banking	UPI (Unified Payments Interface)
Access bank account through bank's website.	Banking through mobile apps.	Cash withdrawal, fund transfer, balance enquiry.	Instant fund transfer using mobile apps (GPay, PhonePe, etc.).
Debit / Credit Card Banking	**NEFT (National Electronic Funds Transfer)**	**RTGS (Real Time Gross Settlement)**	**IMPS (Immediate Payment Service)**
Payments at POS, online purchases, contactless payments.	Electronic transfer of funds (batch processing).	Real-time high value fund transfer (₹ 2 lakh and above).	Instant fund transfer (24 × 7 × 365).

3. Key Features of E-Banking

1. 24 × 7 availability of services.
2. Convenience and time saving.
3. Wide range of services (fund transfer, bill payment, account statement, etc.).
4. Reduced need for physical branches.
5. Integration with digital payment systems (UPI, wallets, etc.).
6. Secure authentication (password, OTP, biometric, etc.).
7. Cost effective and efficient.

4. Advantages and Challenges

Advantages	Challenges / Risks
Convenient and easy access.	Cyber frauds (phishing, vishing, malware, etc.).
Saves time and effort.	Identity theft and unauthorized access.
24 × 7 banking services.	Technical failures and outages.
Faster and paperless transactions.	Lack of digital literacy among users.
Helps in financial inclusion.	Dependence on internet and electronic devices.
Supports digital economy.	Privacy and data security concerns.

5. Regulatory Framework in India

Reserve Bank of India (RBI)
- Regulates and supervises e-banking operations.
- Issues guidelines on security, customer protection and digital payments.

National Payments Corporation of India (NPCI)
- Operates UPI, IMPS, RuPay, etc.
- Ensures secure and efficient payment systems.

Banking Institutions
- Follow RBI guidelines and implement security measures.
- Ensure safe and reliable e-banking services for customers.

6. Related Laws and Legal Provisions

Law / Regulation	Relevance to E-Banking
Information Technology Act, 2000 (amended 2008)	• Legal recognition of electronic records and digital signatures (Sections 3, 4). • Penalties for cyber offences like hacking, identity theft (Sections 43, 66, 66C, 66D).
Reserve Bank of India Act, 1934	• Empowers RBI to regulate banking operations including e-banking.
Payment and Settlement Systems Act, 2007	• Provides legal framework for payment systems like UPI, NEFT, RTGS, IMPS.
Banking Regulation Act, 1949	• Regulates banking companies and their operations, including electronic banking services.
Consumer Protection Act, 2019	• Protects customers in case of unauthorized transactions and service deficiencies.

7. Important RBI Guidelines for E-Banking

1. Two-factor authentication for online transactions.
2. Strong customer authentication (password, OTP, biometric).
3. Liability framework for unauthorized electronic transactions (Circulars on customer compensation).
4. Regular security audits and IT risk management.
5. Customer awareness and grievance redressal mechanism.
6. Guidelines on digital payment security and data protection.

8. Best Practices for Safe E-Banking

- Use strong and unique passwords.
- Enable two-factor authentication.
- Do not share OTP, PIN or bank details.
- Use official bank websites and trusted apps.
- Regularly monitor account statements.
- Keep devices and apps updated.
- Be aware of phishing emails and fake links.
- Report suspicious transactions immediately.



9. Conclusion

- Electronic banking has transformed the Indian banking sector by providing fast, convenient and secure services.
- However, it also brings new risks such as cyber frauds and data breaches.
- Various laws like the IT Act, 2000, RBI Act, Payment and Settlement Systems Act, 2007 and Banking Regulation Act, 1949 provide a legal and regulatory framework for e-banking in India.
- By following security guidelines and regulatory provisions, e-banking can be made safe, reliable and customer friendly.

Q18. Phishing and identity theft / social engineering.

ANS

Phishing and Identity Theft / Social Engineering (10 Marks)

1. Introduction

- Phishing, identity theft and social engineering are common types of cyber attacks that target human behavior rather than technical vulnerabilities.
- Attackers use deception, fake communication and psychological tricks to gain sensitive information such as passwords, bank details or personal data.
- These attacks can lead to financial loss, data theft and misuse of identity.



2. Phishing Attack

- Phishing is a type of social engineering attack where the attacker sends fake emails, messages or websites that appear to be from a trusted source (e.g., bank, company, government).
- The goal is to trick the victim into revealing sensitive information such as usernames, passwords, credit card details, etc.

Working of Phishing Attack

1. Attacker creates a fake email / message / website.
2. Message is sent to many potential victims.
3. Victim clicks on the link and enters sensitive information (on a fake website).
4. Attacker collects the information and misuses it.

3. Types of Phishing (with Examples)

Type	Description	Example
Email Phishing	Fake emails from trusted organizations.	Fake email from bank asking to verify account.
Spear Phishing	Targeted attack on a specific individual or organization.	Email to an employee with personalized details.
Whaling	Targets high-profile individuals (CEOs, managers).	Fake request from CEO for urgent fund transfer.
Clone Phishing	Duplicate of a genuine email with malicious link or attachment.	A genuine email is copied and modified with a fake link.
Smishing	Phishing through SMS (text messages).	Fake SMS about KYC update with a link.
Vishing	Phishing through voice calls.	Caller posing as bank official to get OTP.
Pharming	Redirecting users from a genuine website to a fake website.	Typing bank URL but redirected to fake site.

4. Identity Theft

- Identity theft is the unauthorized use of a person's personal information to impersonate them and commit fraud.
- Stolen information may include: name, address, date of birth, Aadhaar number, PAN number, bank details, login credentials, etc.
- Attackers use this information to open fake accounts, make transactions or carry out criminal activities in the victim's name.



5. Social Engineering

- Social engineering is the art of manipulating people to obtain confidential information.
- It exploits human psychology, trust, fear, curiosity and urgency.
- Attackers do not hack systems directly, but trick users into giving information or performing certain actions.

Common Social Engineering Techniques

Technique	Description
Pretexting	Creating a fake scenario to gain trust.
Baiting	Offering something attractive (e.g., free software).
Quid Pro Quo	Promising a service in exchange for information.
Tailgating	Physically following authorized person to gain access.
Shoulder Surfing	Observing someone's screen or keystrokes.
Impersonation	Pretending to be a trusted person (e.g., IT support, bank official).

6. Prevention Measures

1. Be cautious with emails, messages and calls from unknown sources.
2. Verify the sender's email ID and website URL.
3. Do not click on suspicious links or download unknown attachments.
4. Do not share sensitive information like passwords, OTP, bank details, etc.
5. Use multi-factor authentication (MFA).
6. Keep your software, browser and antivirus up to date.
7. Check website security (https:// and valid certificate).
8. Educate and create awareness about phishing and social engineering.



Be Alert
Think Before You Click

7. Impacts / Consequences

- Financial loss due to unauthorized transactions.
- Misuse of personal identity and sensitive data.
- Damage to reputation and trust.
- Legal and regulatory issues.
- Emotional stress and loss of privacy.
- Can also lead to further attacks like harassment, blackmail or fraud.



8. Conclusion

- Phishing, identity theft and social engineering are serious cyber threats that exploit human behavior.
- They can cause significant financial, personal and organizational damage.
- Awareness, caution and proper security practices can help prevent these attacks.
- Users should always verify information, avoid sharing sensitive data and use security tools like antivirus and multi-factor authentication.
- A combination of technology, awareness and safe online behavior is essential to stay protected.

Q19. Botnets / Trojan horse and backdoor.

ANS

Botnets / Trojan Horse and Backdoor

(10 Marks)

1. Introduction

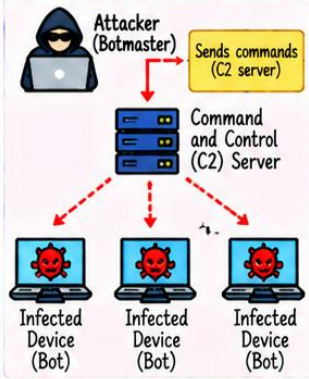
- Malware is a type of malicious software designed to harm a computer system, steal information or gain unauthorized access.
- Botnets, Trojan horse and backdoor are different types of malware, but they are often used together in cyberattacks.
- These threats can lead to data theft, privacy loss, financial loss and can be used to control systems remotely.



2. Botnets

- A botnet is a network of compromised computers (infected with malware) called bots or zombies, which are controlled remotely by an attacker (botmaster).
- These infected devices work together to perform malicious activities without the knowledge of the users.
- Botnets can include computers, servers, smartphones, IoT devices etc.

3. Working of a Botnet



4. Uses / Activities of Botnets

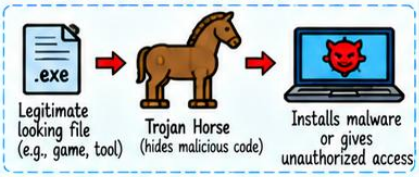
1. Distributed Denial of Service (DDoS) attacks.
2. Sending spam emails.
3. Stealing sensitive information.
4. Hosting malicious websites.
5. Cryptocurrency mining.
6. Spreading other malware.
7. Used in large scale cyberattacks.

Example

- Mirai botnet (targeted IoT devices)
- Zeus botnet (used for financial theft)

5. Trojan Horse

- A Trojan horse is a type of malware that looks like a legitimate or useful software, but actually performs malicious activities when executed.
- It does not replicate on its own like a virus, but relies on the user to install and run it.
- It can create a backdoor, steal data, install additional malware or give remote access to attackers.



6. Examples of Trojan Horse

- Fake software (games, media players, cracks).
- Email attachments claiming to be important documents.
- Free tools or updates from untrusted sources.
- Can be used to steal passwords, install ransomware or create a backdoor.

Working of a Trojan Horse



7. Backdoor

- A backdoor is a hidden method of bypassing normal security authentication to gain unauthorized access to a system.
- It can be installed by attackers using Trojans, or intentionally by insiders (insider threat).
- Once a backdoor is present, attackers can access the system remotely, even if passwords are changed.



8. Uses / Activities of Backdoor

1. Provides unauthorized remote access to system.
2. Allows attackers to execute commands, upload / download files.
3. Can be used to maintain persistent access (even after reboot).
4. Used to steal data, monitor user activity or install more malware.
5. Often used in Advanced Persistent Threats (APTs) and targeted attacks.

Example

- NetBus (backdoor tool)
- Back Orifice
- RATs (Remote Access Trojans)
- Web shells in compromised web servers

9. Comparison: Botnet vs Trojan Horse vs Backdoor

Aspect	Botnet	Trojan Horse	Backdoor
Meaning	Network of infected computers (bots) controlled remotely.	Malware that looks legitimate but performs malicious actions.	Hidden access method to bypass security and gain control.
Nature	Collection of multiple infected devices.	Single malware program.	Hidden entry point (often installed by Trojan or other malware).
User Action	Usually installed silently in background.	Requires user to install or execute the file.	May be installed silently (often by Trojan).
Main Purpose	Perform large scale attacks (DDoS, spam etc.)	Steal data, install malware, create backdoor.	Provide continuous unauthorized access.
Example	Mirai, Zeus	Fake game, software crack	NetBus, Back Orifice

10. Impacts / Consequences

- Data theft and breach of sensitive information.
- Financial loss and fraud.
- System performance degradation.
- Use of devices in illegal activities (spam, DDoS, etc.).
- Loss of privacy and control over system.
- Can be used for surveillance and espionage.
- Reputation damage for individuals and organizations.



11. Prevention Measures

1. Do not download or install software from untrusted sources.
2. Keep operating system and software updated.
3. Use antivirus and anti-malware tools.
4. Enable firewall and intrusion detection systems.
5. Be careful with email attachments and links.
6. Use least privilege access (avoid admin rights).
7. Monitor network traffic for unusual activity.
8. Regularly scan systems and remove suspicious files.
9. Educate users about safe internet practices.

Q20. Cyber cafe illegal activities and safety measures.

ANS

Cyber Cafe Illegal Activities and Safety Measures

(10 Marks)

1. Introduction

- A cyber cafe is a public place that provides computers and internet access to users on payment basis.
- Cyber cafes are useful for students, job seekers and general public, but they can also be misused for various illegal activities.
- Due to easy and anonymous access, cyber cafes are often targeted by criminals to perform illegal and unethical activities.



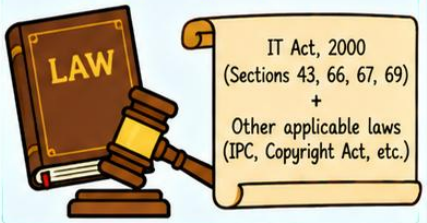
2. Illegal Activities in Cyber Cafe

1. **Access to banned or illegal websites**
   - Visiting sites related to hacking tools, pirated software, pornography, etc.
2. **Cyber crimes**
   - Hacking, spreading malware, phishing attacks, online fraud, identity theft.
3. **Terrorism and anti-national activities**
   - Use of internet for communication, recruitment or planning illegal activities.
4. **Piracy and copyright violations**
   - Downloading or sharing pirated movies, music, software, e-books, etc.
5. **Spreading fake news and hate content**
   - Posting misleading information, rumours or objectionable content on social media.
6. **Online gambling and betting**
   - Accessing illegal gambling or betting websites.
7. **Data theft and misuse**
   - Stealing personal information of other users (saved credentials, browser data, etc.).
8. **Other misuse**
   - Sending spam emails, creating fake accounts, cyber stalking, etc.



3. Legal Provisions in India

- Cyber cafes must follow rules and maintain proper records as per the law.
- Information Technology Act, 2000 (amended 2008) applies to cyber cafe related offences.
- Section 43 – Penalty for unauthorized access, damage to data or systems.
- Section 66 – Punishment for hacking, identity theft, publishing obscene material, etc.
- Section 67 – Punishment for publishing or transmitting obscene material online.
- Section 69 – Power to block public access to certain websites.
- Cyber cafes are required to maintain customer records (identity proof) as per government guidelines.
- Police can monitor and inspect cyber cafes if any illegal activity is suspected.



4. Safety Measures for Cyber Cafe Owners

1. **Verify user identity**
   - Take and maintain valid ID proof (Aadhaar, PAN, Voter ID, etc.).
2. **Maintain user logs**
   - Keep record of user details, date, time, IP address and purpose of use.
3. **Monitor internet usage**
   - Use monitoring software to track websites visited and prevent access to illegal sites.
4. **Use security measures**
   - Install updated antivirus, firewall and anti-malware tools.
5. **Restrict access to banned sites**
   - Block websites related to pornography, gambling, hacking tools, etc.
6. **Regular system maintenance**
   - Keep OS, browser and security software updated.
7. **Awareness and signage**
   - Display rules for users about acceptable internet usage and legal consequences.





5. Safety Tips for Users

1. Use cyber cafe only for legitimate purposes (education, job search, online forms, etc.).
2. Do not share personal or sensitive information (passwords, bank details, OTP, etc.).
3. Logout after use and clear browsing history, cache and cookies.
4. Avoid saving passwords in the browser.
5. Check that you are using a secure website (https://) for online transactions.
6. Do not use cyber cafe computers for internet banking or financial transactions.
7. Be careful while opening emails or downloading files.
8. Use two-factor authentication for important accounts.
9. Report suspicious activities to the owner or authorities.

6. Conclusion

- Cyber cafes provide easy internet access and are useful for many people.
- However, they can be misused for various illegal and unethical activities such as cybercrime, piracy, terrorism, gambling, etc.
- Both owners and users must follow legal guidelines and adopt proper security measures.
- Maintaining user records, monitoring activities and using security tools can help prevent misuse.
- Awareness, responsible usage and strict enforcement of laws are essential to make cyber cafes safe and secure.



USE INTERNET RESPONSIBLY
STAY SAFE
STAY LEGAL

Q21. Virus vs worm

ANS

Virus vs Worm

(10 Marks)

1. Introduction

- Both virus and worm are types of malware (malicious software) that can harm computer systems.
- They can steal data, damage files, reduce system performance and spread to other systems.
- They are different in the way they work, spread and depend on a host.



2. Computer Virus

- A computer virus is a type of malicious program that attaches itself to a legitimate file or program (host).
- It cannot spread on its own, it requires human action (e.g., opening an infected file) to activate and spread.
- When the infected file is executed, the virus code runs and makes copies of itself, which can then infect other files.
- It can perform harmful activities such as deleting files, corrupting data, slowing down the system, etc.

Examples of Virus

- File Infector Virus (e.g., Sality)
- Macro Virus (e.g., Melissa)
- Boot Sector Virus (e.g., Brain)

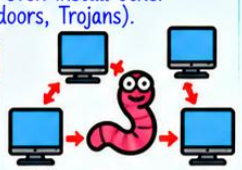


3. Computer Worm

- A computer worm is a type of malicious program that can self-replicate and spread automatically over a network.
- It does not require a host file or human action to spread.
- It exploits security vulnerabilities in operating systems, network services or applications to make copies of itself.
- It can spread through networks, email attachments, removable drives, etc.
- It can consume system resources, slow down networks and even install other malware (e.g., backdoors, Trojans).

Examples of Worm

- ILOVEYOU Worm
- Code Red Worm
- Conficker Worm



4. Difference between Virus and Worm

Aspect	Virus	Worm
Meaning	Malicious program that attaches to a host file and spreads when the file is executed.	Self-replicating program that spreads automatically over a network.
Host requirement	Requires a host file or program.	Does not require a host file.
Mode of spreading	Spreads through infected files, removable drives, email attachments, etc. (needs human action).	Spreads automatically over networks, email systems, security vulnerabilities.
Human intervention	Requires user action to execute the infected file.	No human intervention required.
Replication	Replicates by infecting other files.	Self-replicates and spreads independently.
Speed of spreading	Relatively slow.	Very fast, can spread to many systems quickly.
Main target	Files, programs and system boot sector.	Networks, systems and security vulnerabilities.
Purpose / Impact	Can corrupt or delete files, steal data, slow down system.	Can consume network bandwidth, spread other malware, create backdoors, cause large-scale damage.
Examples	Sality, Melissa, Brain, CIH	ILOVEYOU, Code Red, Conficker, SQL Slammer

5. Working of Virus



6. Working of Worm



7. Prevention Measures

1. Use updated antivirus and anti-malware software.
2. Keep operating system and applications patched.
3. Do not open unknown email attachments.
4. Avoid downloading files from untrusted sources.
5. Use firewall and network security measures.
6. Regularly scan removable drives (USB, etc.).
7. Educate users about safe online practices.

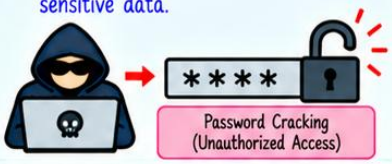
Q22. Password cracking / password policies.

ANS

Password Cracking / Password Policies (10 Marks)

1. Introduction

- A password is a secret combination of characters used to authenticate a user and provide access to a system or application.
- Password cracking is the process of trying to discover or guess a password using various techniques.
- Attackers use automated tools, dictionaries or brute force methods to break weak passwords.
- Strong password policies help in preventing unauthorized access and protect user accounts and sensitive data.



2. Password Cracking Techniques

1	Brute Force Attack	• Tries all possible combinations until the correct password is found. • Time-consuming but effective for short passwords.
2	Dictionary Attack	• Uses a list of commonly used passwords (dictionary). • Fast and effective for weak or common passwords.
3	Hybrid Attack	• Combination of dictionary attack and brute force (adds numbers, symbols, etc.).
4	Rainbow Table Attack	• Uses precomputed hash values (rainbow tables) to crack hashed passwords.
5	Social Engineering	• Tricks users into revealing passwords (e.g., phishing, fake emails, phone calls).
6	Keylogger	• Malware that records keystrokes to capture passwords.

3. Tools Used for Password Cracking

- John the Ripper – popular tool for dictionary and brute force attacks.
- Hashcat – advanced tool for password cracking (supports GPU).
- Hydra – used for online password cracking (e.g., SSH, FTP, HTTP).
- Aircrack-ng – used for cracking Wi-Fi passwords.
- Cain & Abel – used for sniffing passwords on Windows networks.



Example of Cracked Password

4. Impacts / Consequences of Password Cracking

1. Unauthorized access to systems and data.
2. Identity theft and misuse of personal information.
3. Financial loss and online fraud.
4. Data breach and leakage of sensitive information (organizational and personal).
5. Loss of privacy and reputation damage.
6. Can lead to further attacks (installation of malware, spreading to other systems).



5. Password Policies

- A password policy is a set of rules and guidelines to create, use and manage passwords.
- It helps in enforcing strong passwords and reduces the risk of password attacks.
- It is used in organizations, systems and applications to ensure security.
- Good password policies improve authentication security and protect sensitive data from unauthorized access.



6. Key Elements of a Strong Password Policy

1. Minimum length – at least 8–12 characters.
2. Complexity – use uppercase, lowercase, numbers and special characters (e.g., @, #, $, %).
3. Avoid common passwords – do not use dictionary words, personal details (name, DOB, etc.).
4. Regular password change – change periodically (e.g., every 60–90 days).
5. Password history – prevent reuse of old passwords.
6. Account lockout – lock account after multiple failed login attempts.
7. Use of multi-factor authentication (MFA) – additional layer of security.

7. Guidelines for Creating Strong Passwords

- Use a combination of uppercase and lowercase letters (A–Z, a–z).
- Include numbers (0–9).
- Use special characters (@, #, $, %, !, etc.).
- Minimum 8–12 characters (preferably longer).
- Avoid using personal information (name, birth date, phone number, etc.).
- Do not use common or dictionary words.
- Use unique passwords for different accounts.
- Use passphrases (e.g., "My$ecure@2026").
- Enable two-factor authentication (2FA).

Example of Strong Password:
My$ecure@2026
(12 characters, letters + numbers + special character)

8. Conclusion

- Password cracking is a major security threat that can lead to data theft, financial loss and privacy violations.
- Various techniques and tools are used to crack passwords, especially weak and common ones.
- Implementing strong password policies and following best practices can significantly reduce the risk of password attacks.
- Use of strong, unique passwords along with multi-factor authentication provides better protection for systems and sensitive information.
- Awareness and regular security measures are essential to keep accounts safe and secure.



STRONG PASSWORDS = STRONGER SECURITY

UT-2

Q1 Write short notes on: SQL Injection vulnerability and its prevention tactics.

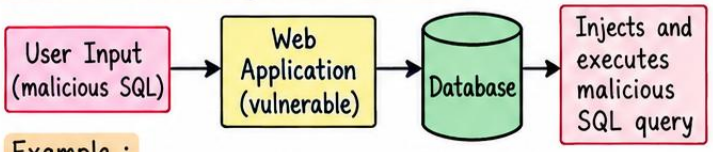
ANS

SQL Injection vulnerability and its prevention tactics (10 Marks)

1) Introduction

- SQL Injection (SQLi) is a type of security vulnerability in which an attacker inserts malicious SQL code into input fields of a web application.
- It exploits the application's lack of input validation and poor database query handling.
- The injected SQL code is executed by the database, which can lead to unauthorized access, data theft, modification or deletion of data.

2) How SQL Injection Works ?



Example :

Normal Query : `SELECT * FROM users WHERE username = 'admin' AND password = '1234';`

Injected Input : `' OR '1'='1 --`

Query becomes : `SELECT * FROM users WHERE username = 'I' OR '1'='1' -- AND password = '1234';`

▶ Here, `'1'='1'` is always true, so the attacker can bypass authentication and login without a valid password.

3) Types of SQL Injection

1. **In-band SQL Injection** : Attacker uses the same channel to both inject the SQL code and receive the results.
2. **Inferential (Blind) SQL Injection** : Attacker does not directly see the results, but infers the database information from the application's behavior (e.g., true/false responses or delays).
3. **Out-of-band SQL Injection** : Attacker uses a different channel (e.g., email or DNS) to steal data when direct results are not available.

4) Impact of SQL Injection

- Unauthorized access to sensitive data (e.g., user credentials, personal information).
- Data modification, deletion or corruption.
- Complete takeover of the database server.
- Compromise of the entire application and system.
- Financial loss and damage to organization's reputation.

5) Prevention Tactics

1. **Use Parameterized Queries (Prepared Statements)**
   Separates SQL code from user input, so input is treated as data, not part of the query.
2. **Input Validation and Sanitization**
   Validate and sanitize all user inputs. Allow only expected data (e.g., numbers, letters) and reject suspicious characters like `'`, `--`, `;` etc.
3. **Use Stored Procedures**
   Stored procedures with proper parameters reduce the risk of SQL injection.
4. **Apply Principle of Least Privilege**
   Use database accounts with minimum necessary permissions (e.g., only SELECT instead of full access).
5. **Use Web Application Firewalls (WAF)**
   WAF can detect and block malicious SQL injection attempts.
6. **Regular Security Testing and Code Review**
   Perform vulnerability scanning, penetration testing and regular code reviews to identify and fix SQL injection flaws.

Q2 What is Steganography? Explain how it differs from cryptography and how it can be used maliciously

ANS

Steganography, its Difference from Cryptography and its Malicious Use

(10 Marks)

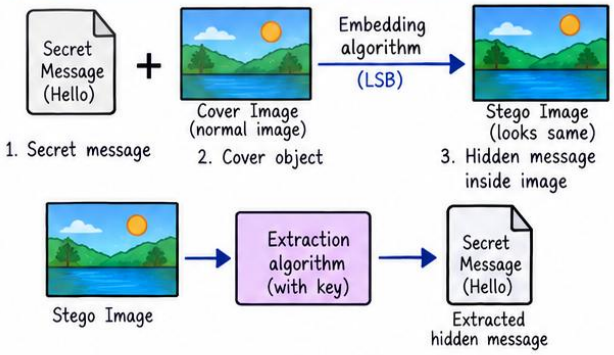
1) What is Steganography?

- Steganography is the technique of hiding secret information inside another non-secret medium (cover object) such as an image, audio, video or text.
- The main goal is to conceal the existence of the message, not just its content.
- It makes the communication look normal and innocent, so that an attacker does not even suspect that a message is being sent.

Example :

A secret message is hidden inside an image. The image looks the same to a normal user, but the hidden data can be extracted using a special tool or key.

2) Working of Steganography (Example: Image)



3) Common Techniques of Steganography

- LSB (Least Significant Bit) – modifies the least significant bits of pixel values in an image.
- Transform domain techniques – use DCT, DWT etc. (used in audio/video steganography).
- Masking and Filtering – hide data in redundant or insignificant parts of a file.
- Spread Spectrum – spreads secret data across the medium.
- Statistical methods – modify data while keeping statistical properties unchanged.

4) Difference Between Steganography and Cryptography

Aspect	Steganography	Cryptography
Main Goal	Hides the existence of the message	Hides the content of the message
Output	Looks like a normal file (image, audio, video, text)	Produces an encrypted (unreadable) message
Visibility	Message is not visible and its presence is concealed	Encrypted message is visible but unreadable
Medium	Uses cover objects (image, audio, video, text)	Can be used for any type of data (text, file, etc.)
Detection	Difficult to detect	Easy to detect (ciphertext looks random)
Example	Hiding text in an image using LSB	Encrypting text using AES, RSA, etc.

5) How Steganography can be used Maliciously?

Steganography can be misused by attackers, criminals or terrorists to hide and secretly transmit illegal or harmful information.

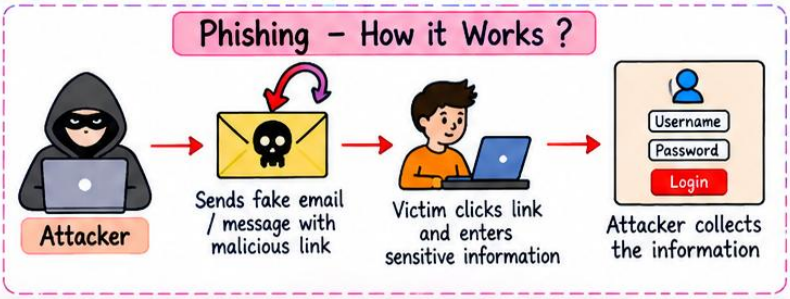
1. **Secret Communication**
   Used by criminals, terrorists or espionage agents to communicate without raising suspicion.
2. **Data Exfiltration**
   Sensitive or confidential data can be hidden inside images or other files and sent out of an organization without being detected.
3. **Malware Distribution**
   Malicious code can be hidden inside an image, audio or video file and sent via email or social media.
4. **Command and Control (C2)**
   Used to hide commands for malware or botnets inside innocent-looking files.
5. **Bypassing Security Filters**
   Helps in bypassing firewalls, intrusion detection systems and content filtering as the file appears to be normal.
6. **Illegal Content Sharing**
   Can be used to hide and share illegal or prohibited content (e.g., child exploitation material) inside images or videos.

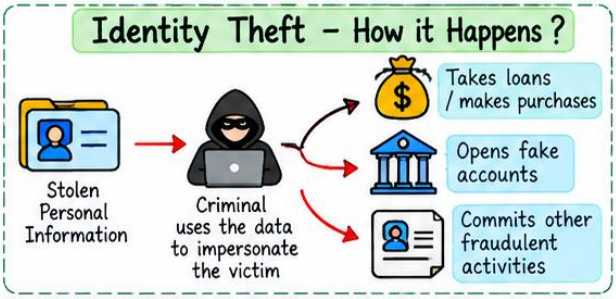
Q3 Difference Between Phishing vs. Identity Theft (ID Theft)

ANS

Difference Between Phishing vs Identity Theft (ID Theft)

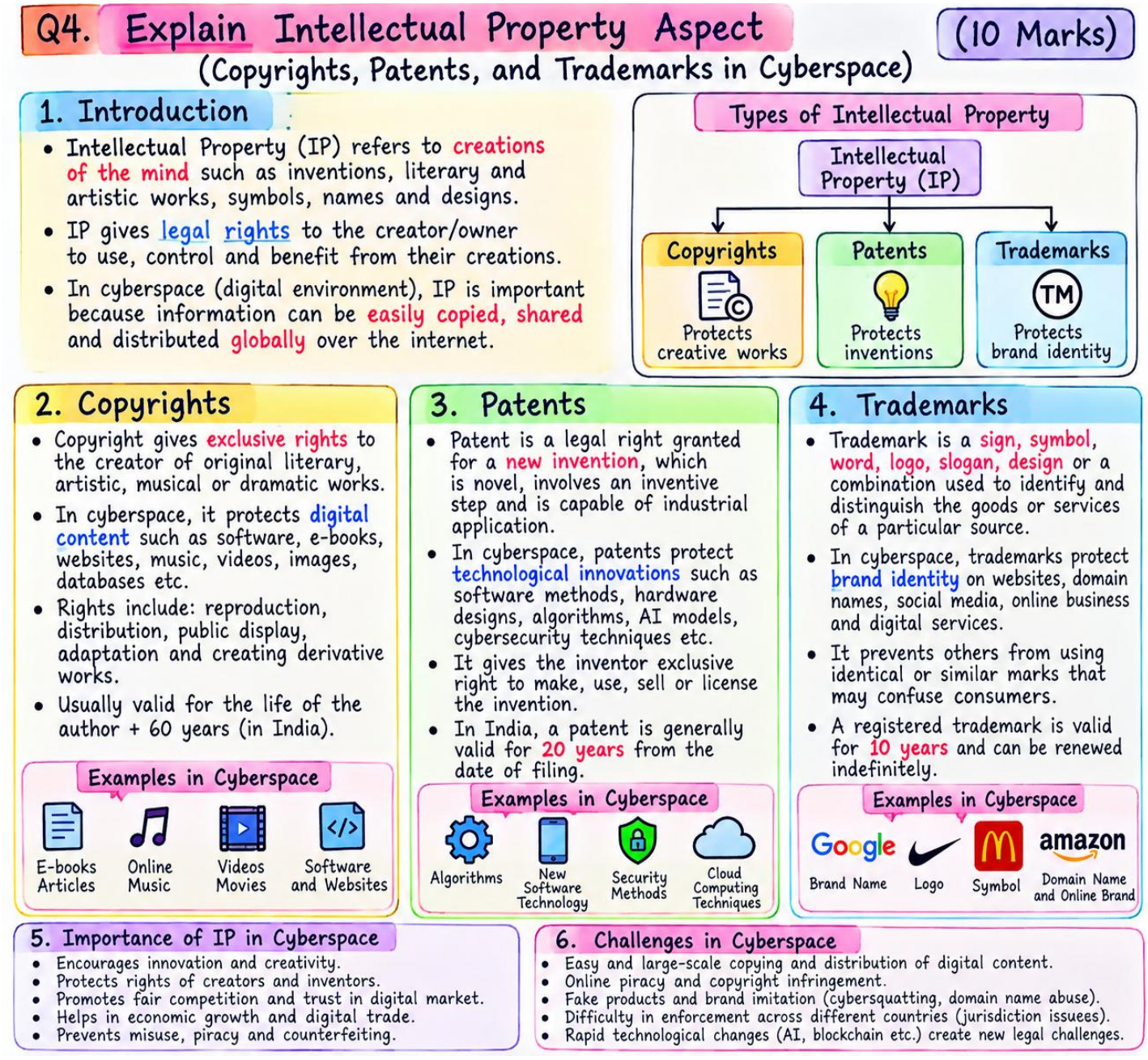
	Aspect	Phishing	Identity Theft (ID Theft)
1.	Meaning	A cyber attack technique where attackers try to trick users into giving sensitive information (via fake emails, messages, websites).	Unauthorized use of someone's personal information to impersonate them and commit fraud or other crimes.
2.	Main Goal	To steal sensitive information (e.g., usernames, passwords, OTPs, bank details).	To use stolen personal information to illegally impersonate the victim and gain financial or other benefits.
3.	Nature	A method / attack (means to obtain data).	A crime / illegal activity (end result using stolen data).
4.	Type	A form of social engineering.	A type of fraud / cybercrime.
5.	What is targeted?	Directly targets people (victims) to trick them.	Uses the victim's personal information to target institutions (banks, government, services).
6.	Information involved	Usually seeks sensitive data like login credentials, credit card details, OTPs, etc.	Uses personal information such as name, address, date of birth, Aadhaar/SSN, bank details, etc.
7.	Form	Often comes via email, SMS, phone call, fake websites, accial media messages.	Involves misuse of personal information for financial gain, opening fake accounts, loans, etc.
8.	Occurs	At the initial stage (to collect information).	After information has been stolen (can result from phishing or other means).
9.	Victim Awareness	Victims may realize soon if they notice fake links or suspicious messages.	Victims often realize much later, when they see unauthorized transactions or credit issues.
10.	Impact	Loss of credentials, compromise of accounts, which can lead to further attacks.	Financial loss, damage to credit score, legal problems, and long-term consequences.
11.	Example	Fake email from bank asking to "verify your account" with a link to a fake website.	Using someone's stolen Aadhaar or credit card details to take a loan or make purchases.
12.	Prevention	Be cautious of suspicious emails/links, verify sender, use multi-factor authentication, don't share credentials.	Protect personal information, monitor accounts, use strong security measures, report if data is misused.





Q4 Explain Intellectual Property Aspect (Copyrights, Patents, and Trademarks in cyberspace).

ANS



Q5 Explain the Objectives and features of IT Act, 2000

ANS

Objectives and Features of IT Act, 2000

Objectives of IT Act, 2000

1. **Provide legal recognition to electronic records and digital signatures.**
   To give the same legal validity to electronic documents and digital signatures as paper documents and handwritten signatures.
2. **Facilitate e-commerce and e-governance.**
   To promote electronic business transactions and online services by providing a legal framework.
3. **Prevent and punish cyber crimes.**
   To define various cyber offences and prescribe penalties for unauthorized access, hacking, identity theft, etc.
4. **Establish a regulatory framework.**
   To set up authorities such as the Controller of Certifying Authorities (CCA) for regulating digital signature certificates.
5. **Protect data and privacy.**
   To safeguard sensitive personal data and ensure reasonable security practices.
6. **Promote use of information technology.**
   To encourage the growth and development of IT and the digital economy in India.
7. **Provide legal framework for intermediaries.**
   To define the role and liability of intermediaries such as ISPs, network providers, etc.
8. **Amend other laws to include cyber aspects.**
   To modify IPC, Evidence Act, Bankers' Books Evidence Act, and RBI Act to deal with electronic records and cyber offences.

Some Important Sections of IT Act, 2000

- Section 3 – Digital Signature.
- Section 4 – Legal recognition to electronic records.
- Section 43 – Penalty for damage to computer, system or network.
- Section 66 – Hacking with computer system (punishment).
- Section 66C – Identity theft.
- Section 66D – Cheating by personation using computer resources.
- Section 66E – Violation of privacy.
- Section 69 – Power to intercept, monitor or decrypt information.
- Section 79 – Intermediary liability (safe harbour).

Features of IT Act, 2000

1. **Legal recognition to electronic records**
   Electronic records are given the same legal validity as paper documents (Section 4).
2. **Recognition of digital signatures**
   Digital signatures are legally valid (Section 3) and a framework for Digital Signature Certificates (DSC) is provided.
3. **Establishment of Controller of Certifying Authorities (CCA)**
   CCA is set up to regulate Certifying Authorities (CAs) who issue digital signature certificates.
4. **Definition of cyber offences**
   Defines offences like hacking (Sec 66), data theft, identity theft (Sec 66C), cheating by personation (Sec 66D), and violation of privacy (Sec 66E).
5. **Prescribes penalties and punishments**
   Provides imprisonment and fines for various cyber crimes (e.g., up to 3 years or more depending on the offence).
6. **Amendments to other laws**
   Amends IPC, Indian Evidence Act, Bankers' Books Evidence Act and RBI Act to include electronic records and cyber offences.
7. **Intermediary liability and safe harbour**
   Provides conditional protection to intermediaries (ISPs, network providers) for third-party content (Section 79).
8. **Data protection provisions**
   Provides safeguards for sensitive personal data (Section 43A) and requires reasonable security practices.
9. **Facilitates e-governance and e-commerce**
   Enables online contracts, filings, and delivery of government services.
10. **Extraterritorial jurisdiction**
    Applies to offences committed outside India if they involve a computer, system or network located in India (Section 75).

Conclusion

- The IT Act, 2000 provides the legal backbone for a secure and trustworthy digital environment in India.
- It promotes the use of information technology, enables e-governance and e-commerce, and addresses cyber crimes and related legal issues.
- The Act has been amended in 2008 to cover new technologies and stronger data protection measures.

Q6 Explain in detail the mechanism of DoS (Denial of Service) and DDoS (Distributed Denial of Service) attacks. What are the common mitigation techniques?

ANS

DoS (Denial of Service) and DDoS (Distributed Denial of Service) Attacks

(10 Marks)

1) What is DoS ?

- Denial of Service (DoS) is an attack in which an attacker intentionally sends a large number of requests or malicious traffic to a target system (server, network or website) to consume its resources.
- As a result, legitimate users are unable to access the service.
- It is usually launched from a single source (attacker's machine).

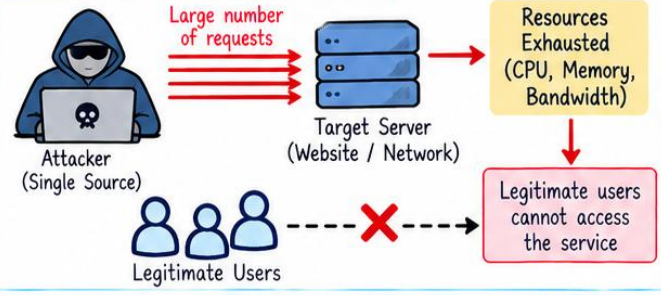
2) What is DDoS ?

- Distributed Denial of Service (DDoS) is a more powerful form of DoS attack where the attacker uses multiple compromised systems (botnets) from different locations to flood the target with traffic.
- The traffic comes from many sources, making it difficult to block.
- It is larger in scale and more difficult to mitigate than a simple DoS attack.

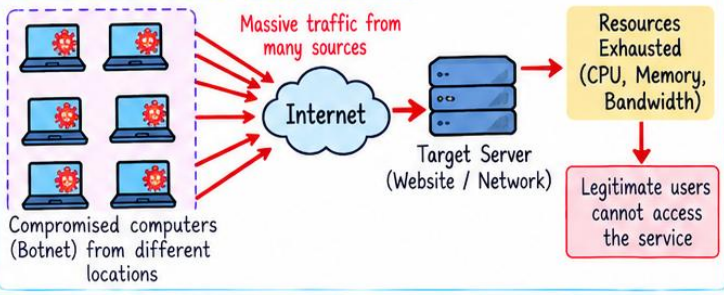
3) DoS vs DDoS

Aspect	DoS	DDoS
Source	Single attacker system	Multiple compromised systems (botnets)
Scale	Smaller scale	Very large scale
Traffic	From one source	From many sources distributed globally
Detection	Easier to detect and block	Difficult to detect and block
Impact	Service unavailable to legitimate users	Same, but for longer duration and higher damage

4) Mechanism of DoS Attack



5) Mechanism of DDoS Attack



6) Common Types / Methods of DoS/DDoS Attacks

Type of Attack	Mechanism	Example	Effect
Volumetric Attack	Floods target with huge amount of traffic to consume bandwidth.	UDP flood, ICMP (flood), DNS amplification	Network bandwidth saturation
Protocol Attack	Exploits weaknesses in network protocols to consume server resources.	SYN flood (half-open connections)	Exhausts server connection table
Application Layer Attack	Sends a large number of legitimate-looking requests to application layer (HTTP).	HTTP flood, Slowloris	Consumes CPU, memory and application resources
Amplification Attack (mainly DDoS)	Uses vulnerable servers to send a small request and get a very large response.	DNS amplification, NTP amplification	Generates massive traffic towards victim

7) Impact of DoS/DDoS Attacks

- Service unavailability to legitimate users.
- Loss of revenue and business reputation.
- Disruption of critical services (e.g., e-commerce, banking, government websites).
- Increased operational and recovery costs.
- Can be used as a distraction for other attacks.



8) Mitigation Techniques

1. Use firewalls and intrusion detection/prevention systems (IDS/IPS) to filter malicious traffic.
2. Traffic filtering and rate limiting to block abnormal traffic.
3. Use CDN (Content Delivery Network) and cloud-based DDoS protection services (e.g., Cloudflare, AWS Shield).
4. Deploy load balancing and redundancy to distribute traffic.
5. Use anti-DDoS appliances and traffic scrubbing centers (ISP level).
6. Keep systems and applications updated to fix vulnerabilities.
7. Monitor network traffic and set up anomaly detection.

Q7 Why is there a critical need for an Indian Cyber Law? Discuss the evolution and significance of cyber law frameworks.

ANS

Why is there a critical need for an Indian Cyber Law? Discuss the evolution and significance of cyber law frameworks

Need for Indian Cyber Law

1. Rapid growth of IT and internet usage in India.
2. Increase in cyber crimes (hacking, identity theft, online fraud, data breaches, cyber terrorism).
3. Existing laws (IPC, Evidence Act, etc.) were not adequate to deal with digital offences.
4. Need to give legal recognition to electronic records and digital signatures.
5. Protection of sensitive personal and corporate data.
6. To regulate e-commerce, online contracts and digital transactions.
7. To define liability of intermediaries (ISPs, network providers, etc.).
8. To ensure national security and prevent cyber terrorism.
9. To build trust and confidence in e-governance and digital services.
10. To align with international standards and promote global cooperation.

Significance of Cyber Law Frameworks

1. Provides legal recognition to electronic records and digital signatures.
2. Helps in prevention, detection and investigation of cyber crimes.
3. Establishes penalties and punishments for cyber offences.
4. Protects personal data, privacy and intellectual property rights.
5. Regulates e-commerce and e-governance transactions.
6. Defines liability of intermediaries and promotes accountability.
7. Enhances national security and helps in combating cyber terrorism.
8. Builds trust in digital transactions and online services.
9. Encourages international cooperation and alignment with global cyber laws.

Evolution of Cyber Law Frameworks in India

Before 2000 — Traditional Legal Framework
- Indian Penal Code, 1860, and Indian Evidence Act, 1872 were used to deal with cyber offences.
- These laws were not sufficient for digital crimes.



2000 — Information Technology Act, 2000
- First comprehensive law for cyber space in India.
- Provided legal recognition to electronic records and digital signatures.
- Defined cyber offences and prescribed penalties.



2008 — Amendment Act, 2008
- Included new offences (identity theft, cyber terrorism, stalking, etc.).
- Recognized intermediaries and introduced data protection provisions.



2011 — Rules and Guidelines
- IT (Intermediary Guidelines) Rules, 2011.
- Strengthened obligations of social media platforms and intermediaries.



2022 — CERT-In Directions and Data Protection Initiatives
- Strengthened incident reporting and cybersecurity measures.
- Steps towards Personal Data Protection framework.



Ongoing — Towards Digital India and Global Alignment
- New laws and policies for data protection, privacy and emerging technologies (AI, cloud, IoT).
- India is aligning with international cyber laws and participating in global cooperation.



Impact on Society and Economy



Safer online transactions



Protection of citizen rights



Supports e-governance and Digital India



Reduces cyber crimes



Boosts digital economy

Q8 Discuss Legal Framework for Electronic Data Interchange

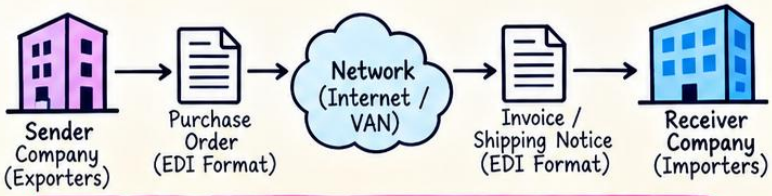
ANS

Q8. Discuss Legal Framework for Electronic Data Interchange (10 Marks)

1. Introduction

- Electronic Data Interchange (EDI) is the **electronic exchange of business documents** such as purchase orders, invoices, shipping notices etc. between organizations in a standard format.
- It replaces paper-based transactions and enables **fast, secure** and **automated** business communication over computer networks (Internet/Private networks).

2. What is EDI? (Working)



Business documents are exchanged electronically in a standard and legally valid format.

3. Need for Legal Framework

- To give **legal recognition** to electronic documents and electronic signatures.
- To ensure **authenticity**, **integrity** and non-repudiation of EDI transactions.
- To **resolve disputes** related to electronic contracts and records.
- To build trust and confidence in online business transactions.
- To promote e-commerce and international trade by removing legal barriers.

4. Legal Framework for EDI

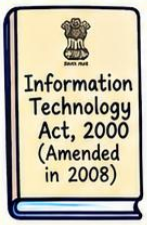
The legal framework for EDI is based on national laws, international agreements and standardization bodies.

International Laws and Model Laws
↓
National Laws (India)
↓
Standards and Guidelines
↓
Contractual Agreements
↓
Dispute Resolution Mechanisms

5. Key Legal Elements

1. **Legal Recognition of E-Documents**
   - Electronic records and signatures are **legally valid**.
2. **Electronic Signatures**
   - Used to **authenticate** the sender and ensure data integrity.
3. **Electronic Contracts**
   - Online contracts formed through EDI are **legally enforceable**.
4. **Data Integrity and Security**
   - Use of encryption, digital signatures and secure communication.
5. **Liability and Jurisdiction**
   - Defines responsibility in case of fraud, data loss or breach.

6. Legal Provisions in India



- Recognizes electronic records as legal documents (Section 4).
- Recognizes electronic signatures (Section 3).
- Provides legal validity to electronic contracts (Section 10A).
- Covers security, privacy and protection of electronic data.
- Defines penalties for cyber offences related to data tampering and fraud.

7. International Framework

- **UNCITRAL Model Law on Electronic Commerce (1996)**
  - Provides a legal framework for cross-border electronic transactions.
- **United Nations Convention on the Use of Electronic Communications in International Contracts (2005)**
  - Supports the use of electronic communications in international trade.
- **WTO and global trade agreements**
  - Promotes e-commerce and reduces legal barriers.

8. Challenges

- Different legal systems across countries.
- Issues of **jurisdiction** in cross-border transactions.
- Recognition of electronic signatures globally.
- Data **privacy** and **security** concerns.
- Risk of fraud, data tampering and unauthorized access.
- Need for harmonization of international laws and standards.

9. Importance / Benefits

- Provides **legal certainty** to EDI transactions.
- Encourages e-commerce and global trade.
- Reduces paper work and **transaction cost.**
- Improves efficiency and speed of business processes.
- Helps in building trust and secure digital business environment.

10. Conclusion

- A strong legal framework is essential for the smooth and secure implementation of EDI. Laws like the Information Technology Act, 2000 in India, along with international agreements such as UNCITRAL model law, provide recognition to electronic records, signatures and contracts. This framework builds **trust**, encourages e-commerce and supports **global trade** in the digital era.

UT-1

Q1. Explain the need of cyber law in India.

ANS

Need of Cyber Law in India

Cyber law refers to the laws that regulate the use of computers, the internet, digital communication, and cyberspace. With the rapid growth of information technology, online banking, e-commerce, social media, and digital services, cyber law has become essential in India.

The need for cyber law in India can be explained as follows:

1. **To control cyber crimes:** Cyber law helps in dealing with offences such as hacking, identity theft, online fraud, cyberbullying, data theft, and other computer-related crimes.
2. **To provide legal recognition to electronic records:** It gives legal validity to electronic documents, digital records, and electronic transactions, making paperless communication and business possible.

3. **To recognize digital signatures:** Cyber law provides legal recognition to digital signatures and electronic authentication, ensuring the authenticity and security of online transactions.
4. **To promote e-commerce:** It creates a legal framework for online buying, selling, electronic contracts, and digital payments, thereby promoting the growth of e-commerce in India.
5. **To protect data and privacy:** Cyber laws help protect personal and sensitive information from unauthorized access, misuse, and disclosure.
6. **To ensure cyber security:** These laws encourage organizations and individuals to take necessary measures to protect computer systems, networks, and digital information from cyber attacks.
7. **To fix liability and provide punishment:** Cyber law defines various cyber offences and provides penalties and legal remedies against offenders, helping victims obtain justice.
8. **To regulate online activities:** It helps regulate the activities of individuals, companies, intermediaries, and service providers operating in cyberspace.
9. **To support e-governance:** Legal recognition of electronic records and signatures enables government departments to provide services electronically and improves efficiency and transparency.
10. **To maintain trust in the digital environment:** A proper legal framework increases the confidence of citizens and businesses in using the internet and digital technologies safely.

Conclusion

Thus, cyber law is necessary in India to create a **safe, secure, and legally regulated digital environment**. It protects users, prevents and punishes cyber crimes, promotes e-commerce and e-governance, and supports the growth of India's digital economy. The **Information Technology Act, 2000**, is the primary law dealing with cyber-related legal issues in India.

Q2. Explain various security challenges posed by mobile devices

ANS

Various Security Challenges Posed by Mobile Devices

Mobile devices such as smartphones and tablets are widely used for communication, online banking, e-commerce, social media, and accessing organizational data. Their portability and constant internet connectivity create several security challenges.

1. Loss or Theft of Devices

Mobile devices are small and portable, so they can easily be lost or stolen. If the device is not properly secured, unauthorized persons may access personal, financial, or confidential data.

2. Malware and Malicious Applications

Users may download applications from untrusted sources. Such malicious apps can contain malware, spyware, or viruses that can steal information or damage the device.

3. Data Leakage

Mobile devices store a large amount of sensitive information such as contacts, messages, passwords, documents, and banking details. Improper security can lead to unauthorized disclosure or leakage of this data.

4. Weak Authentication

Using weak passwords, simple PINs, or no screen lock makes it easier for unauthorized users to access the device and its stored information.

5. Insecure Wireless Networks

Mobile devices frequently connect to public Wi-Fi, Bluetooth, and other wireless networks. Insecure connections may expose data to interception or unauthorized access.

6. Phishing and Social Engineering Attacks

Attackers may send fake messages, emails, links, or notifications to trick users into revealing passwords, banking details, or other sensitive information.

7. Operating System and Application Vulnerabilities

Outdated operating systems and applications may contain security vulnerabilities. Attackers can exploit these weaknesses to gain unauthorized access to the device.

8. Privacy Issues

Mobile applications may collect personal information such as location, contacts, camera access, and other user data. Excessive or unauthorized collection of such information can affect user privacy.

9. BYOD (Bring Your Own Device) Issues

In organizations, employees may use their personal devices for official work. This can create security problems because organizational data may be stored on devices that are not fully controlled by the organization.

10. Cloud and Synchronization Risks

Mobile devices often synchronize data with cloud services. If cloud accounts or synchronization settings are not properly secured, sensitive data may become accessible to unauthorized users.

Conclusion

Mobile devices face many security challenges due to their portability, internet connectivity, and storage of sensitive information. Therefore, strong passwords, regular software updates, trusted applications, secure networks, encryption, and proper security policies are necessary to protect mobile devices and their data.

Exam tip: For a **10-mark Mumbai University answer**, write the introduction, explain **any 8–10 points**, and add the conclusion.

Q3. What are Botnets? How is it exploited by an attacker to cause a cyber-attack?

ANS

Definition of Botnet

A **botnet** is a network of computers, mobile devices, or other internet-connected devices that have been compromised by malicious software and are controlled remotely by an attacker. Each infected device is called a **bot** or **zombie**.

The attacker who controls the botnet is often called a **botmaster**. The attacker can send commands to multiple infected devices and use them together to perform cyber-attacks.

How a Botnet is Exploited to Cause a Cyber-Attack

The working and exploitation of a botnet can be explained in the following steps:

1. **Infection of Devices**
   The attacker spreads malicious software through unsafe downloads, malicious links, infected applications, or other security weaknesses. Devices that become compromised join the botnet.

2. **Formation of a Network of Bots**
   Many infected devices are connected to form a network. The owners of these devices may not be aware that their devices are being misused.

3. **Remote Command and Control**
   The attacker communicates with and controls the infected devices using a command-and-control mechanism. Commands can be sent to many bots simultaneously.

4. **Launching Distributed Attacks**
   Since a botnet contains many compromised devices, the attacker can use their combined resources to carry out large-scale attacks.

5. **DDoS Attacks**
   A common use of a botnet is a **Distributed Denial-of-Service (DDoS) attack**, where many compromised devices generate excessive traffic towards a target, making its services slow or unavailable.

6. **Sending Spam and Phishing Messages**
   Botnets can be used to send a large number of unwanted emails or fraudulent messages to many users.

7. **Stealing Information**
   Malware associated with compromised devices may collect sensitive information, such as login credentials or personal data, and send it to the attacker.

8. **Spreading Malware**
   A botnet can help spread malicious software to additional devices, increasing the size and impact of the attack.

9. **Disruption of Services**
   Attackers may use the combined power of infected devices to disrupt websites, networks, or online services, causing financial and operational losses.

10. **Maintaining Large-Scale Cyber Attacks**
    Because the attack originates from multiple compromised devices, it can be more difficult for defenders to identify and block all malicious traffic quickly.

Simple Diagram

Attacker / Botmaster

↓

Command and Control

↓

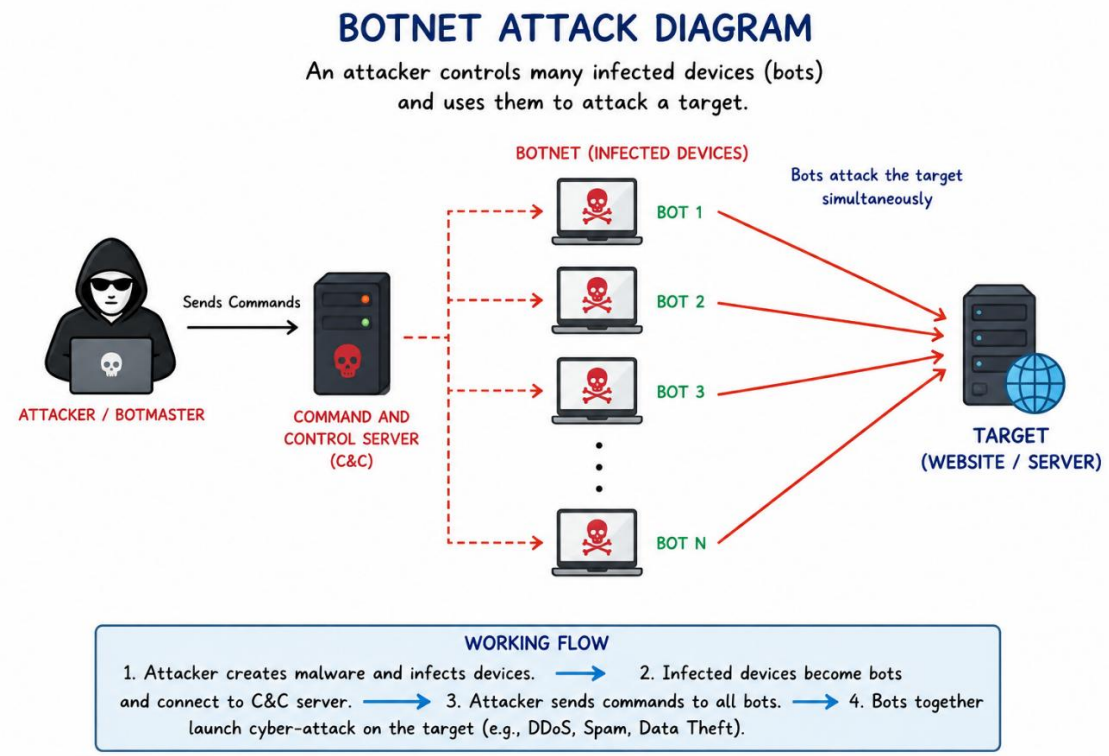
Bot 1 + Bot 2 + Bot 3 + … + Bot N

↓

Combined Cyber-Attack on Target

Conclusion

A botnet is a powerful cyber-attack mechanism because it uses a large number of compromised devices under the control of an attacker. Botnets can be exploited for DDoS attacks, spam, phishing, malware distribution, information theft, and service disruption. Therefore, updated software, antivirus protection, strong authentication, and safe internet practices are important to prevent devices from becoming part of a botnet.



Q4. Explain how criminals plan the attack

ANS

Cyber criminals generally plan an attack in a systematic manner. They first identify a target, gather information, look for weaknesses, and then attempt to misuse those weaknesses for illegal purposes.

For a **10-mark answer**, the planning process can be explained in the following points:

1. Selecting the Target

The criminal first chooses a target such as an individual, organization, website, computer system, or network. The target may be selected based on the value of its information or the presence of possible security weaknesses.

2. Information Gathering

The attacker collects publicly available information about the target, such as its website, technologies used, online presence, and organizational structure. This helps them understand the target environment.

3. Identifying Weaknesses

The criminal looks for security weaknesses such as outdated software, weak passwords, insecure configurations, or careless user practices.

4. Planning the Attack Method

Based on the information collected, the attacker decides the general method of attack. For example, they may attempt phishing, malware-based attacks, unauthorized access, or service disruption.

5. Preparing Resources

The criminal may arrange the required infrastructure and malicious tools, such as compromised systems or other resources, to support the planned attack.

6. Attempting Initial Access

The attacker tries to gain unauthorized access by exploiting a weakness or deceiving a user. This is often the starting point of the attack.

7. Expanding Access

After gaining access, the criminal may attempt to access additional systems or information within the target environment.

8. Achieving the Criminal Objective

The attack is carried out to achieve an illegal objective, such as stealing information, committing fraud, disrupting services, or demanding money.

9. Avoiding Detection

Cyber criminals may try to reduce the chances of immediate detection and make it harder for security teams to identify unauthorized activity.

10. Reviewing the Attack

Finally, the attacker evaluates whether the objective was achieved and may use the results to improve future attacks.

Simple Flow Diagram

Target Selection
↓
Information Gathering
↓
Identify Weaknesses
↓
Plan Attack Method
↓
Prepare Resources
↓
Attempt Unauthorized Access
↓
Achieve Criminal Objective

Q5. Differentiate between cybercrime and traditional terrestrial crime

ANS

Difference Between Cybercrime and Traditional (Terrestrial) Crime

Parameter	Cybercrime	Traditional / Terrestrial Crime
1. Meaning	Crime committed using computers, networks, or the internet.	Crime committed in the physical or real world.
2. Medium of Crime	Uses digital devices, computer systems, and communication networks.	Usually involves physical actions, objects, or direct interaction.
3. Location	Can be committed from any location through the internet.	Generally occurs at a specific physical location.
4. Geographical Boundaries	Can easily cross national and international boundaries.	Usually limited to a particular geographical area or jurisdiction.
5. Identity of Criminal	The criminal may hide their identity using digital methods.	The criminal is more likely to be physically identified through witnesses or evidence.
6. Speed of Crime	Can be carried out and spread very quickly.	Usually requires physical presence and may take more time.
7. Number of Victims	A single attack can affect thousands or millions of users.	Generally affects a limited number of victims at a time.
8. Evidence	Digital evidence includes logs, emails, files, IP information, and electronic records.	Physical evidence includes fingerprints, weapons, documents, and eyewitness accounts.
9. Investigation	Requires knowledge of computers, networks, and digital forensics.	Mainly involves traditional investigation methods and physical evidence.
10. Examples	Hacking, phishing, identity theft, online fraud, and malware attacks.	Theft, robbery, assault, burglary, and other physical crimes.

Conclusion

Thus, **cybercrime is committed in cyberspace using digital technology**, whereas **traditional or terrestrial crime is generally committed in the physical world**.

Cybercrime is often faster, can cross geographical boundaries, and requires specialized techniques for investigation.

Q6. Define cybercrime and classify its types ?

ANS

Define Cybercrime and Classify Its Types

Definition of Cybercrime

Cybercrime refers to any illegal or unauthorized activity in which a **computer, computer network, digital device, or the internet** is used as a tool, target, or place for committing a crime.

In cybercrime, the computer may be:

- **The target** of the crime, such as hacking a computer system.
- **The tool** used to commit the crime, such as online fraud.
- **Both a tool and a target** in certain cyber offences.

Classification of Cybercrime

Cybercrimes can be broadly classified into the following types:

1. Crimes Against Individuals

These crimes target a particular person or group of individuals.

Examples:

- Identity theft
- Phishing
- Cyberbullying
- Online harassment
- Email spoofing
- Defamation
- Online financial fraud

Example: A criminal steals a person's personal information and misuses it to commit fraud.

---

2. Crimes Against Property

These crimes involve damage, theft, or unauthorized use of digital or intellectual property.

Examples:

- Data theft
- Intellectual property theft
- Software piracy
- Computer vandalism
- Malware attacks
- Ransomware attacks

Example: Stealing confidential files or illegally copying copyrighted software.

---

3. Crimes Against Organizations

These cybercrimes target companies, institutions, and other organizations.

Examples:

- Unauthorized access or hacking
- Data breaches
- Denial-of-Service (DoS) attacks
- Distributed Denial-of-Service (DDoS) attacks
- Malware attacks
- Theft of confidential business information

Example: Attacking an organization's website and making its online services unavailable.

---

4. Crimes Against Society

These crimes affect society or a large group of people.

Examples:

- Spreading fake information
- Online gambling and illegal activities
- Distribution of illegal or harmful digital content
- Large-scale online scams
- Circulation of malicious content

Such crimes can create social, economic, and security-related problems.

---

5. Crimes Against Government

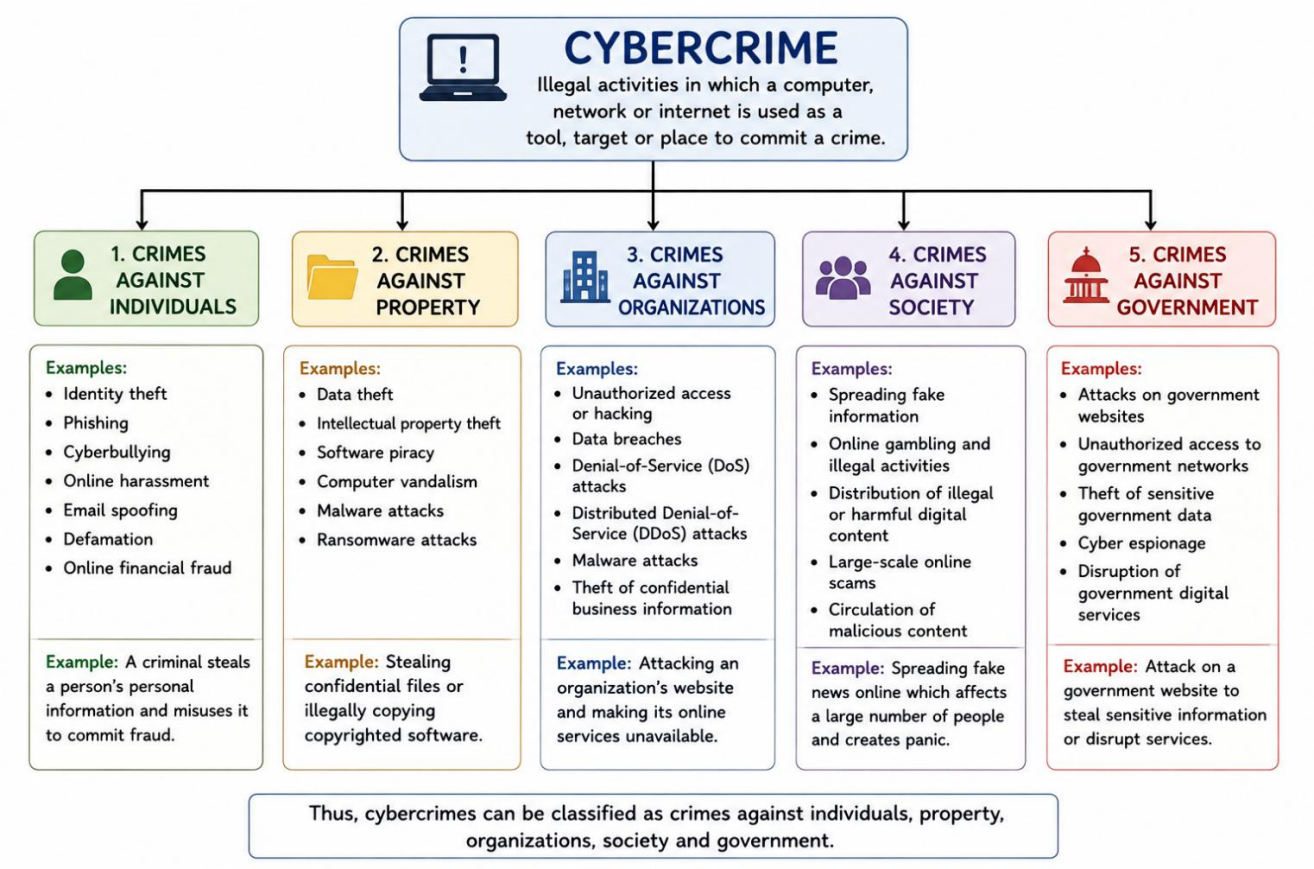
These crimes target government systems, networks, websites, and sensitive information.

Examples:

- Attacks on government websites
- Unauthorized access to government networks
- Theft of sensitive government data
- Cyber espionage
- Disruption of government digital services

These attacks may affect national security and public services.

Simple Classification Diagram



Q7. What is social engineering? Explain different types of social engineering attacks.

ANS

Social Engineering and Its Types

Definition of Social Engineering

Social engineering is a technique in which an attacker manipulates, deceives, or influences people to make them reveal confidential information, perform unsafe actions, or provide unauthorized access to a system.

Instead of directly attacking a computer or network, the attacker mainly **targets human behavior**, such as trust, fear, curiosity, urgency, or lack of awareness.

Example: An attacker sends a fake message pretending to be from a bank and tries to trick a user into revealing sensitive account information.

Types of Social Engineering Attacks

1. Phishing

Phishing is an attack in which fake emails, messages, or websites are used to trick users into providing sensitive information such as usernames, passwords, or financial details.

Example: A fake bank email asking the user to verify their account.

---

2. Spear Phishing

Spear phishing is a targeted form of phishing in which the attacker sends a specially designed message to a particular person or organization.

It is usually more personalized than ordinary phishing.

---

3. Whaling

Whaling is a type of phishing attack that specifically targets important or senior persons in an organization, such as executives or managers.

The attacker may try to obtain confidential business information or gain access to important accounts.

---

4. Vishing

Vishing (Voice Phishing) involves using phone calls or voice messages to deceive victims.

The attacker may pretend to be a bank employee, customer support representative, or government official to obtain sensitive information.

---

5. Smishing

Smishing (SMS Phishing) is a social engineering attack carried out through SMS or text messages.

The message may contain a fraudulent link or request designed to trick the user.

---

6. Pretexting

In pretexting, the attacker creates a false identity or believable situation to gain the victim's trust and obtain information.

Example: An attacker pretends to be an IT support employee and requests account-related information.

---

7. Baiting

Baiting involves offering something attractive or interesting to encourage a victim to take an unsafe action.

The bait may be a fake offer, free software, or other tempting content that leads the victim towards a security risk.

---

8. Quid Pro Quo

In a **quid pro quo** attack, the attacker offers a benefit, service, or assistance in exchange for information or some action from the victim.

For example, a fake support person may offer technical assistance to gain the victim's trust.

---

9. Tailgating or Piggybacking

Tailgating occurs when an unauthorized person gains access to a restricted physical area by following an authorized person.

Example: An unauthorized person enters a secure office area by closely following an employee through an access-controlled door.

---

10. Scareware

Scareware uses fake warnings or alarming messages to create fear or panic and pressure users into taking an unsafe action.

Example: A fake warning claims that the user's device has a serious security problem and asks them to take immediate action.

